

CSE190/291

How The Web Tracks You / Targeted Advertising

Stateful Tracking, Part 1

UC San Diego

Housekeeping

General course things to know

- PA1, parts 1 + 2 are released!
 - Part 2 due Tuesday, 10/13 (one week from today!)
- Implementing a full-scale “web application” that does some stateful tracking, using cookies, to track your behavior on a Google search competitor (Boogle)
 - Cookie-based tracking, databases, and server side logic
- **No class on 10/13!**
 - work on your PAs :)
- PA1, parts 3 + 4 *should* release on **10/14**

Housekeeping (CSE190 Only)

General course things to know

- If you want to take this class P/NP, you can, but if you are a CSE major and using this for your degree requirements, you cannot.
- Talk to student advising if you need more guidance!

Previously on CSE190/CSE291...

- We've talked about the basics of networking, the web, and HTTP as it relates to this class
- We discussed databases, the basics of SQL, and how you interface with databases to store things you need...

Let's do a recap.

- What is a client-server architecture?

Let's do a recap.

- What is a client-server architecture?
 - A system architecture where *clients* make requests and *servers* respond to those requests. What is the protocol that the web uses to implement it's client-server paradigm?

Let's do a recap.

- What is a client-server architecture?
 - A system architecture where *clients* make requests and *servers* respond to those requests. What is the protocol that the web uses to implement it's client-server paradigm?
- HTTP! What does HTTP stand for?

Let's do a recap.

- What is a client-server architecture?
 - A system architecture where *clients* make requests and *servers* respond to those requests. What is the protocol that the web uses to implement it's client-server paradigm?
- HTTP! What does HTTP stand for?
 - HyperText Transport Protocol. Originally used for sending files, nowadays, used for *everything*

An HTTP Request

- HTTP requests — chiefly include a **method** (e.g., GET, POST), and a **path** (e.g., /index.html).



HTTP Request Anatomy

- What does an HTTP Request look like?

```
GET /index.html HTTP/1.1
```

```
Accept: image/gif, image/x-bitmap, image/jpeg, */*
```

```
Accept-Language: en
```

```
Connection: Keep-Alive
```

```
User-Agent: Mozilla/1.22 (compatible; MSIE 2.0; Windows 95)
```

```
Host: www.example.com
```

```
Referer: http://www.google.com?q=dingbats
```


HTTP Request Anatomy

- What does an HTTP Request look like?

Method Path Protocol Version

```
GET /index.html HTTP/1.1
```

```
Accept: image/gif, image/x-bitmap, image/jpeg, */*
```

```
Accept-Language: en
```

```
Connection: Keep-Alive
```

```
User-Agent: Mozilla/1.22 (compatible; MSIE 2.0; Windows 95)
```

```
Host: www.example.com
```

```
Referer: http://www.google.com?q=dingbats
```

HTTP Request Anatomy

- What does an HTTP Request look like?

```
GET /index.html HTTP/1.1
```

```
Accept: image/gif, image/x-bitmap, image/jpeg, */*
```

```
Accept-Language: en
```

```
Connection: Keep-Alive
```

```
User-Agent: Mozilla/1.22 (compatible; MSIE 2.0; Windows 95)
```

```
Host: www.example.com
```

```
Referer: http://www.google.com?q=dingbats
```

HTTP Headers

HTTP Request Anatomy

- What does an HTTP Request look like?

```
GET /index.html HTTP/1.1
```

```
Accept: image/gif, image/x-bitmap, image/jpeg, */*
```

```
Accept-Language: en
```

```
Connection: Keep-Alive
```

```
User-Agent: Mozilla/1.22 (compatible; MSIE 2.0; Windows 95)
```

```
Host: www.example.com
```

```
Referer: http://www.google.com?q=dingbats
```

Referer header!

HTTP Request Anatomy

- What does an HTTP Request look like?

```
GET /index.html HTTP/1.1
```

```
Accept: image/gif, image/x-bitmap, image/jpeg, */*
```

```
Accept-Language: en
```

```
Connection: Keep-Alive
```

```
User-Agent: Mozilla/1.22 (compatible; MSIE 2.0; Windows 95)
```

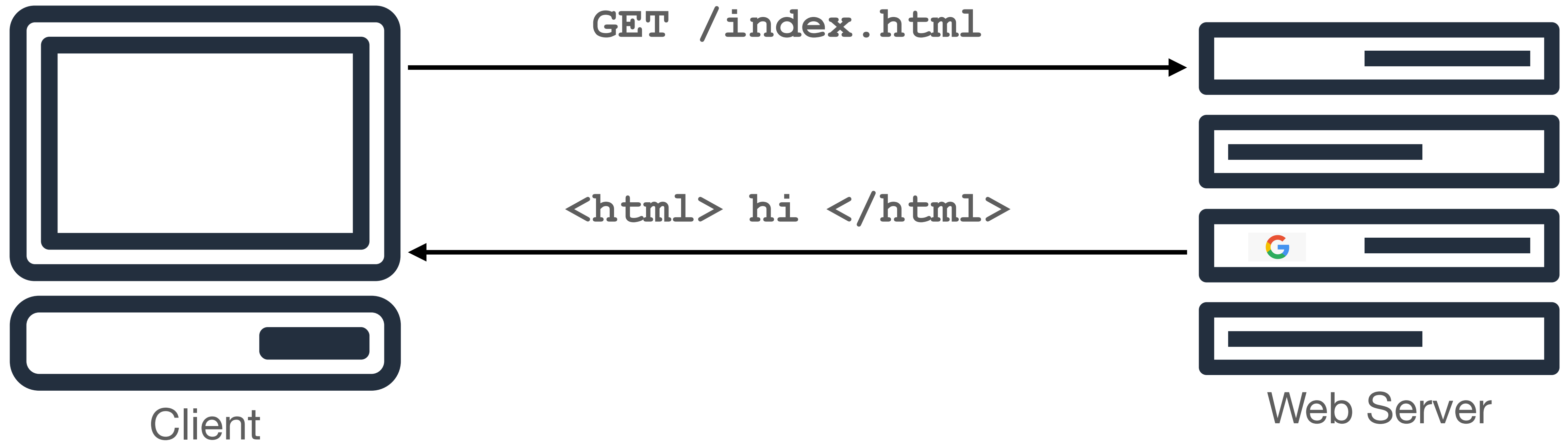
```
Host: www.example.com
```

```
Referer: http://www.google.com?q=dingbats
```

Body (usually empty for GET requests)

An HTTP Response

- HTTP response — chiefly include a **status code** (e.g., 200, 300, 404), and **data** (e.g., some HTML).



HTTP Response Anatomy

- What does an HTTP Response look like?

```
HTTP/1.0 200 OK
Date: Sun, 21 Apr 1996 02:20:42 GMT
Server: Microsoft-Internet-Information-Server/5.0
Connection: keep-alive
Content-Type: text/html
Last-Modified: Thu, 18 Apr 1996 17:39:05 GMT
Set-Cookie: ...
Content-Length: 2543
```

HTTP Response Anatomy

- What does an HTTP Response look like?

Status Code

```
HTTP/1.0 200 OK
Date: Sun, 21 Apr 1996 02:20:42 GMT
Server: Microsoft-Internet-Information-Server/5.0
Connection: keep-alive
Content-Type: text/html
Last-Modified: Thu, 18 Apr 1996 17:39:05 GMT
Set-Cookie: ...
Content-Length: 2543
```

HTTP Response Anatomy

- What does an HTTP Response look like?

Status Code

```
HTTP/1.0 200 OK
```

```
Date: Sun, 21 Apr 1996 02:20:42 GMT
```

```
Server: Microsoft-Internet-Information-Server/5.0
```

```
Connection: keep-alive
```

```
Content-Type: text/html
```

```
Last-Modified: Thu, 18 Apr 1996 17:39:05 GMT
```

```
Set-Cookie: ...
```

```
Content-Length: 2543
```

HTTP Headers

HTTP Response Anatomy

- What does an HTTP Response look like?

Status Code

```
HTTP/1.0 200 OK
```

```
Date: Sun, 21 Apr 1996 02:20:42 GMT
```

```
Server: Microsoft-Internet-Information-Server/5.0
```

```
Connection: keep-alive
```

```
Content-Type: text/html
```

```
Last-Modified: Thu, 18 Apr 1996 17:39:05 GMT
```

```
Set-Cookie: ...
```

```
Content-Length: 2543
```

HTTP Headers

```
<html> hi </html>
```

Let's do a recap.

- What is a client-server architecture?
 - A system architecture where *clients* make requests and *servers* respond to those requests. What is the protocol that the web uses to implement it's client-server paradigm?
- HTTP! What does HTTP stand for?
 - HyperText Transport Protocol. Originally used for sending files, nowadays, used for *everything*
- What software implements HTTP for us when we're browsing the web?

Let's do a recap.

- What is a client-server architecture?
 - A system architecture where *clients* make requests and *servers* respond to those requests. What is the protocol that the web uses to implement it's client-server paradigm?
- HTTP! What does HTTP stand for?
 - HyperText Transport Protocol. Originally used for sending files, nowadays, used for *everything*
- What software implements HTTP for us when we're browsing the web?



Today's lecture — Stateful Tracking, Pt. 1

Learning Objectives

- Understand the browser execution model — how browsers implement the *web* for us, the components they use, and the problems therein
- Discuss the composition of webpages, first-party and third-party resources, and cookies
- Learn what a cookie really is, why it's so powerful as a tracker, and walk through some examples of how cookies are passed around on the web
- Begin to understand the third-party tracking ecosystem, the underlying software that supports it, and what we might do about it

Web Execution

Where is there code running?

Client / Server Model



Client



Web Server

Where is there code running?

Client / Server Model



Client

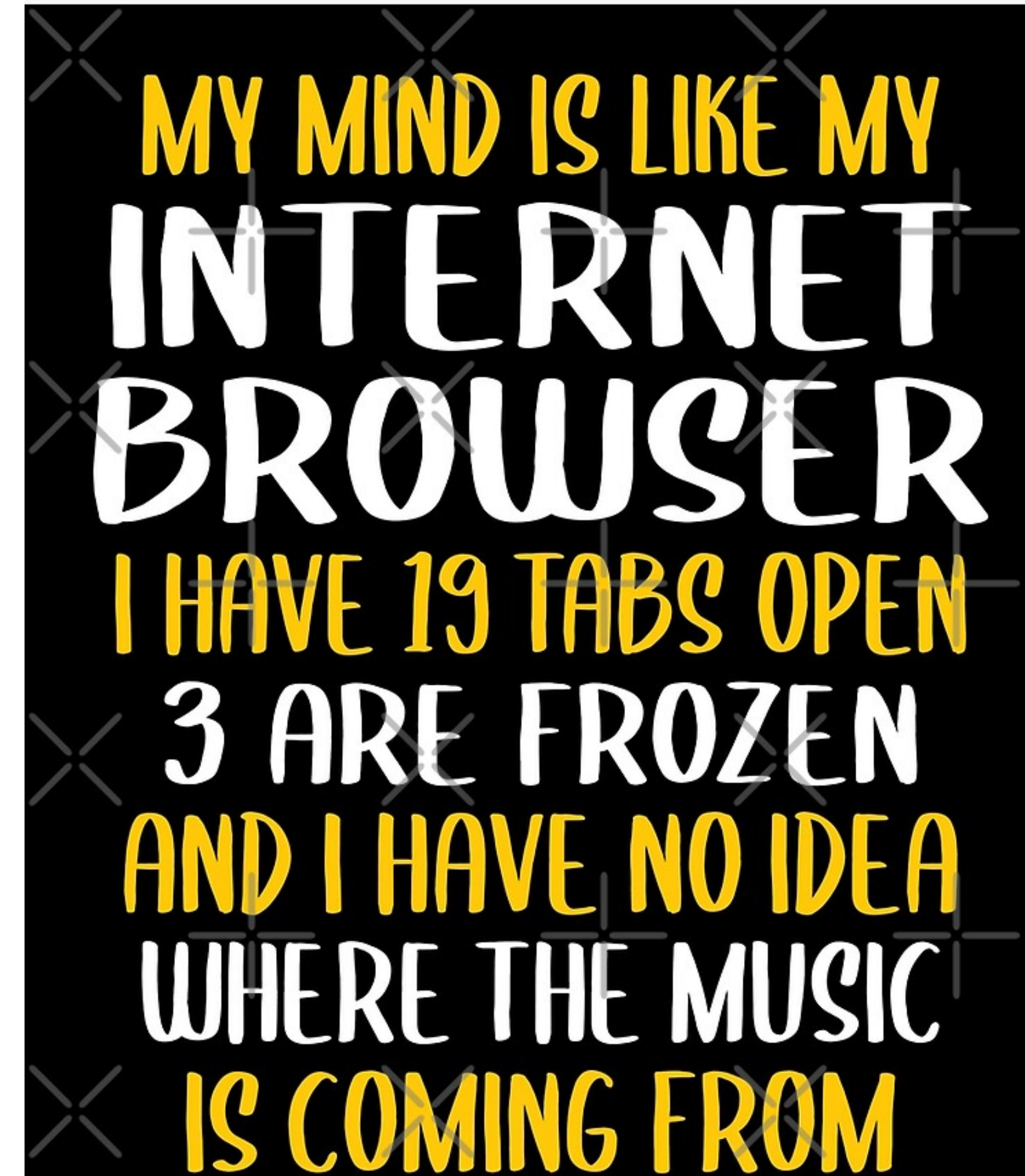
Code is running on the **server** (e.g., Python, Go, C), on the **client** (e.g., Chrome, Firefox), and *in the client* (e.g., JavaScript)



Web Server

Browsers do lots of things...

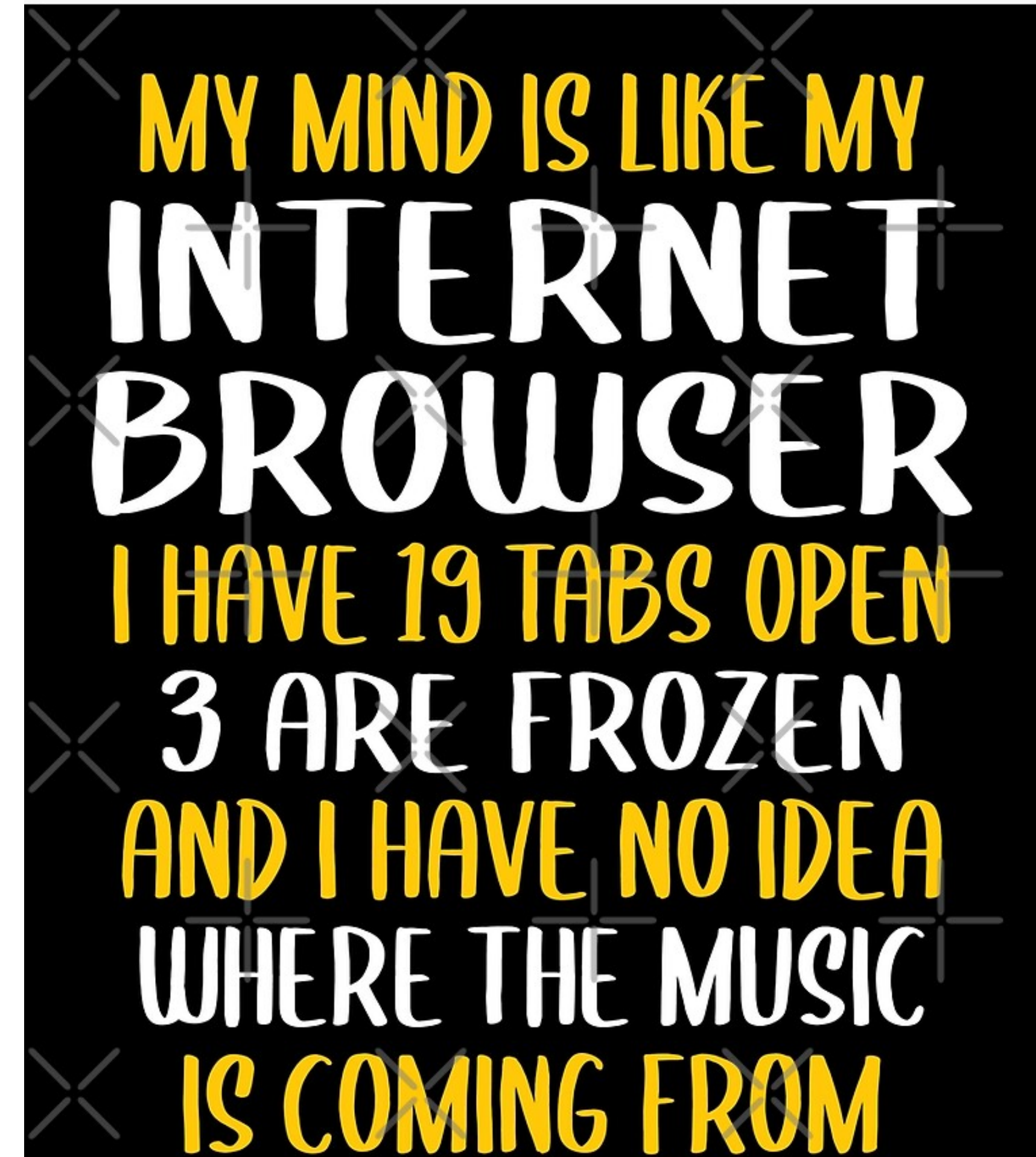
- With a group, get together and answer the following questions:
 - What are some responsibilities of web browsers?
 - In what ways do browsers protect users or protect user data?



MY MIND IS LIKE MY
INTERNET
BROWSER
I HAVE 19 TABS OPEN
3 ARE FROZEN
AND I HAVE NO IDEA
WHERE THE MUSIC
IS COMING FROM

Browsers do lots of things...

- With a group, get together and answer the following questions:
 - **What are some responsibilities of web browsers?**
 - In what ways do browsers protect users or protect user data?



MY MIND IS LIKE MY
INTERNET
BROWSER
I HAVE 19 TABS OPEN
3 ARE FROZEN
AND I HAVE NO IDEA
WHERE THE MUSIC
IS COMING FROM

Browser Responsibilities

- Making network requests
 - DNS, HTTPS, caching, redirecting, etc.

Browser Responsibilities

- Making network requests
 - DNS, HTTPS, caching, redirecting, etc.
- Parsing and rendering HTML

Hypertext Markup Language (HTML)

- Webpages follow a Document Object Model (DOM) — this is the structure of the page itself (encoded via HTML, sometimes XML)
- The page itself is a *tree* of *nodes* designated by *tags* (e.g., `<div></div>`)
- HTML can designate page layout, but *also* network requests...

```
1  <!DOCTYPE html>
2  <html>
3      <head>
4          <title>Example</title>
5          <link rel="stylesheet" href="style"
6      </head>
7      <body>
8          <h1>
9              <a href="/">Header</a>
10         </h1>
11         <nav>
12             <a href="one/">One</a>
13             <a href="two/">Two</a>
14             <a href="three/">Three</a>
15         </nav>
```

Browser Responsibilities

- Making network requests
 - DNS, HTTPS, caching, redirecting, etc.
- Parsing and rendering HTML
- Storage
 - LocalStorage

Browser Responsibilities

- Making network requests
 - DNS, HTTPS, caching, redirecting, etc.
- Parsing and rendering HTML
- Storage
 - LocalStorage
- UI —> navigating the web (fwd, backwards buttons, etc.)

Browser Responsibilities

- Making network requests
 - DNS, HTTPS, caching, redirecting, etc.
- Parsing and rendering HTML
- Storage
 - LocalStorage
- UI —> navigating the web (fwd, backwards buttons, etc.)
- Accessing the underlying OS
 - WebGPU, WebGL, etc.

Browser Responsibilities

- Making network requests
 - DNS, HTTPS, caching, redirecting, etc.
- Parsing and rendering HTML
- Storage
 - LocalStorage
- UI —> navigating the web (fwd, backwards buttons, etc.)
- Accessing the underlying OS
 - WebGPU, WebGL, etc.
- Running code (JavaScript)

Browser Responsibilities

- Making network requests
 - DNS, HTTPS, caching, redirecting, etc.
- Parsing and rendering HTML
- Storage
 - LocalStorage
- UI —> navigating the web (fwd, backwards buttons, etc.)
- Accessing the underlying OS
 - WebGPU, WebGL, etc.
- Running code (JavaScript)

Browsers are the modern day OS.



JavaScript in action — where is the code?

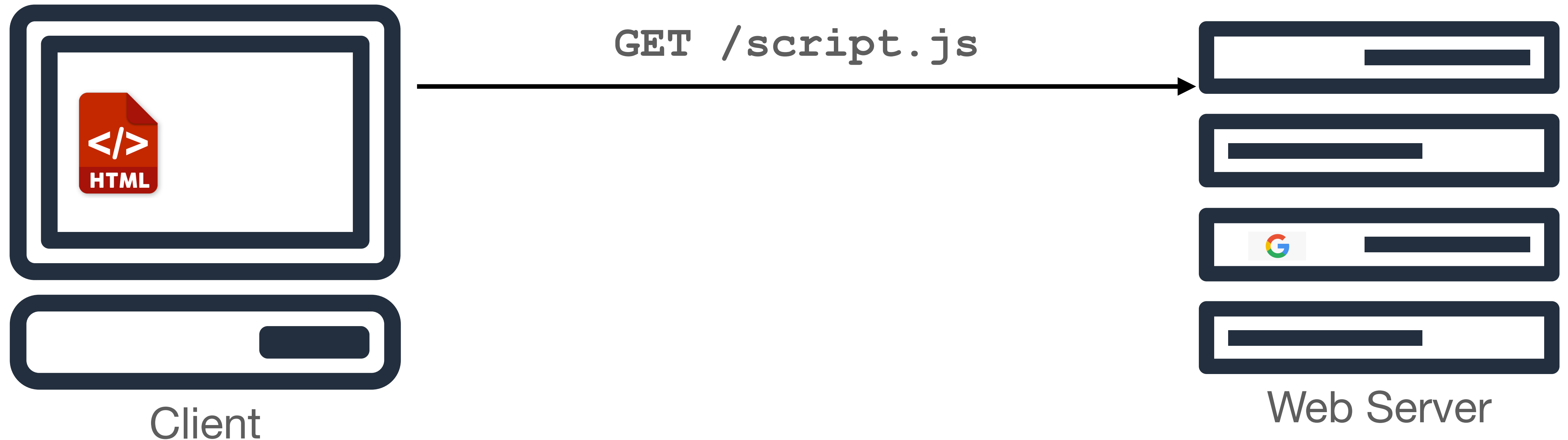


Client

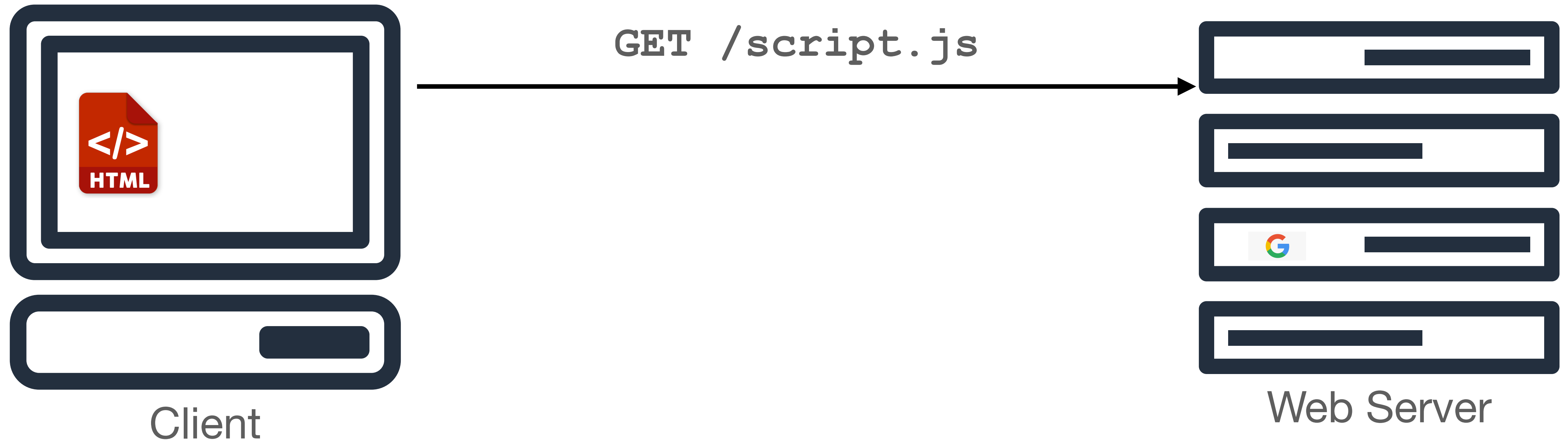


Web Server

JavaScript in action — where is the code?

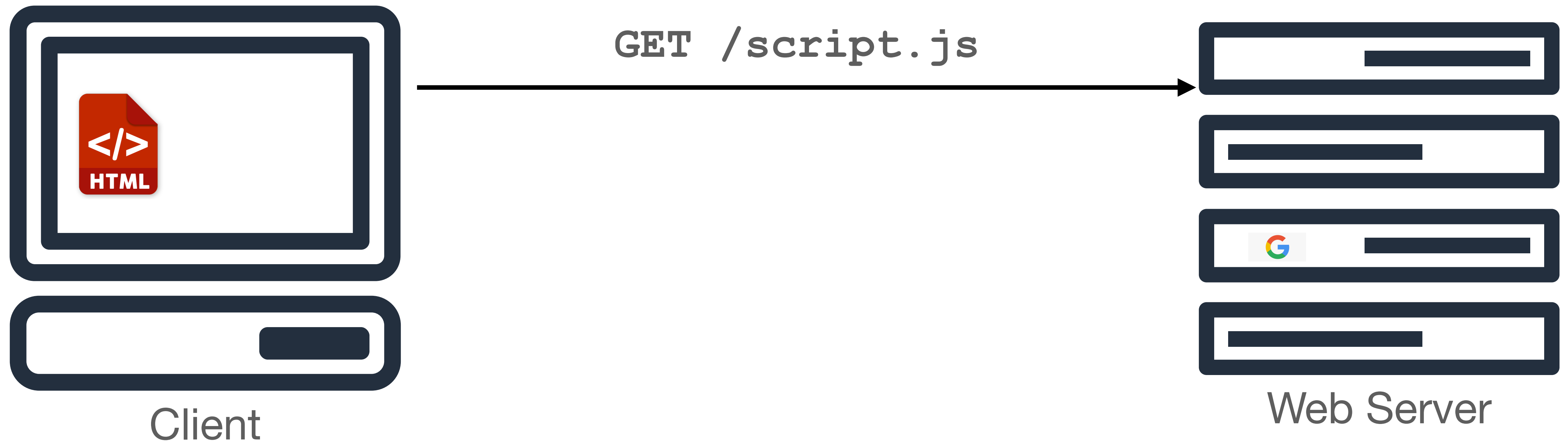


JavaScript in action — where is the code?



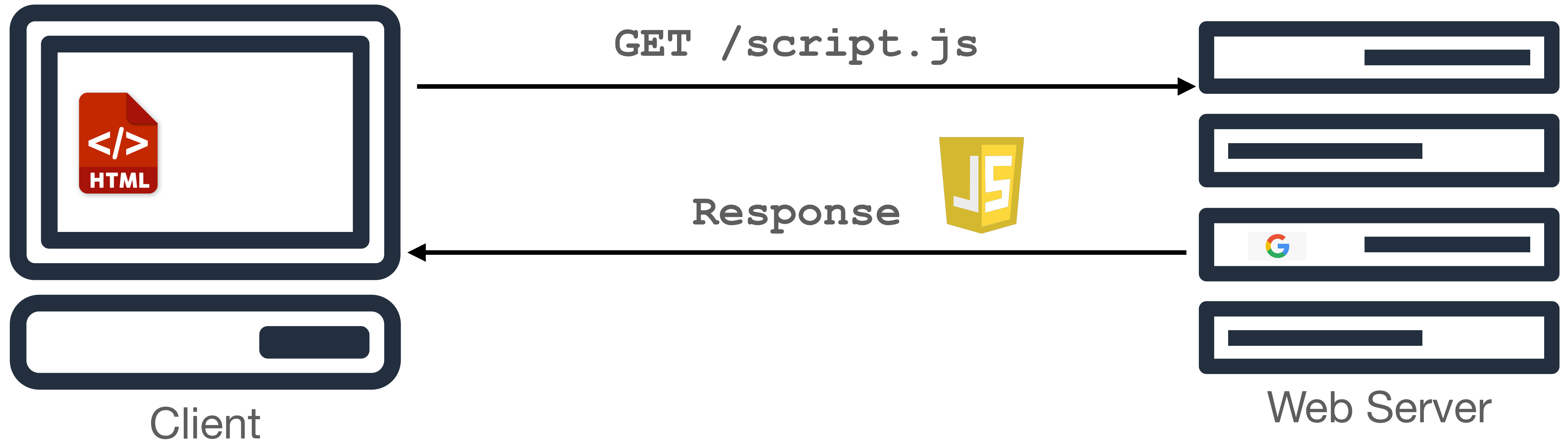
Why might the browser be making a request for script.js?

JavaScript in action — where is the code?



Where is script.js being served from?

JavaScript in action — where is the code?



JavaScript in action — where is the code?



Client



Web Server

Is `script.js` run by the *client* or by the server?

Where is JavaScript running?

- Chrome has developed its own high-performance JavaScript (and wasm) engine in C++
- If you've ever used `node.js`, it's the same underlying engine
- ~ 2.3 million lines of C++ code that is under constant development...
- Seems totally unproblematic... if you're curious, take 127





Student Information

Find a Student

Student Holds
Report



Hold Types

Course Tools

Schedule of Classes

My Timetable



Error

Triton Enrollment
Authorization
Review



TEA

Event(booking)
Report



Class List
BAH Report



Student Information

Find a Student

Student Holds
Report

Hold Types

Course Tools

Schedule of Classes

My Timetable



Error

Triton Enrollment
Authorization
Review

TEA

Event(booking)
ReportClass List
BAH Report

Does TSS run in the client or on the server?

UC San Diego

Home

2

DK

My Home

Admin

Instructor

Student Information

Find a Student

Student Holds Report

Hold Types

Course Tools

Schedule of Classes

My Timetable

Triton Enrollment Authorization Review

Event(booking) Report

Class List BAH Report

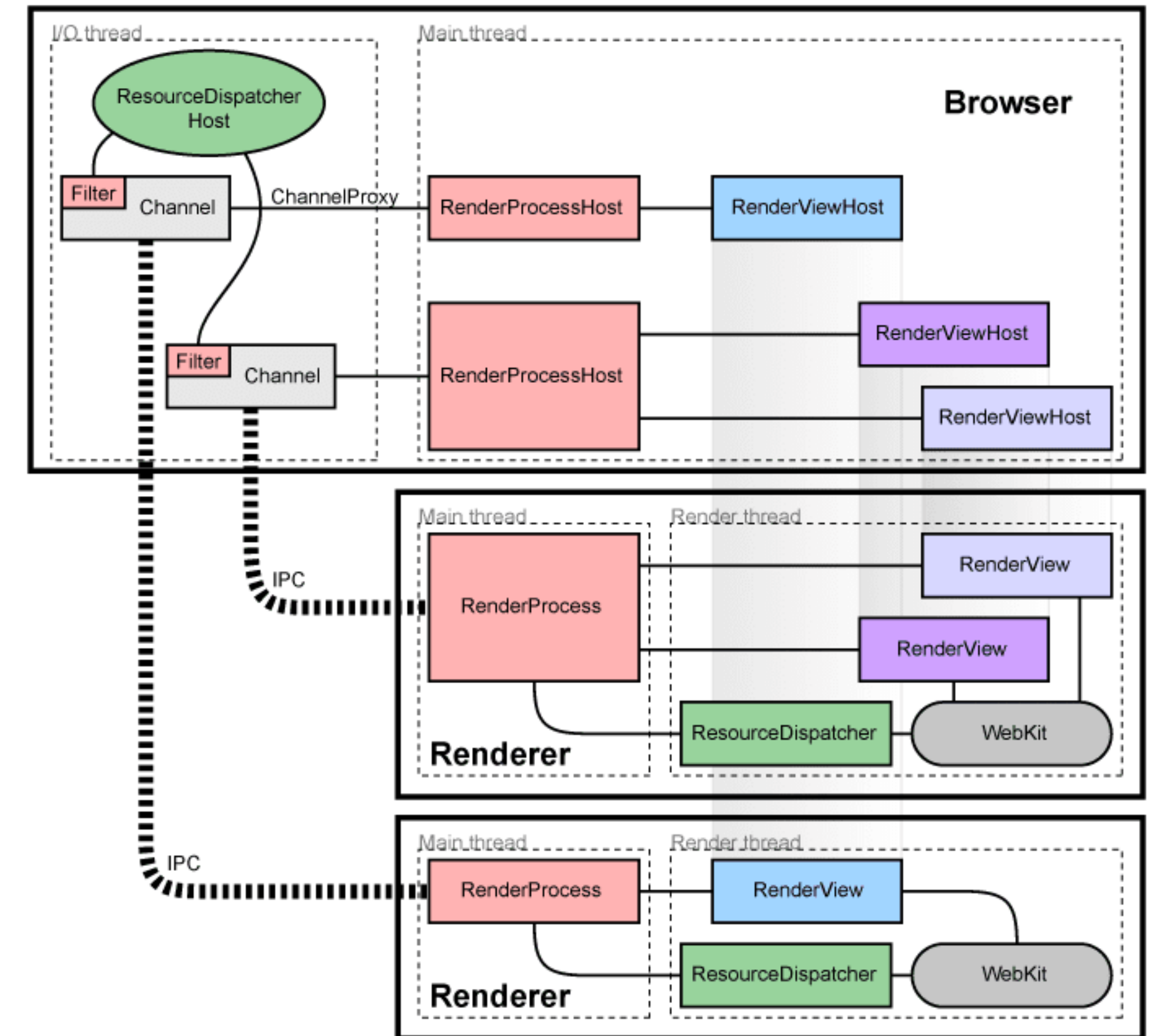
Does TSS run in the client or on the server?

BOTH!

What parts are running on the server? What parts on the client?

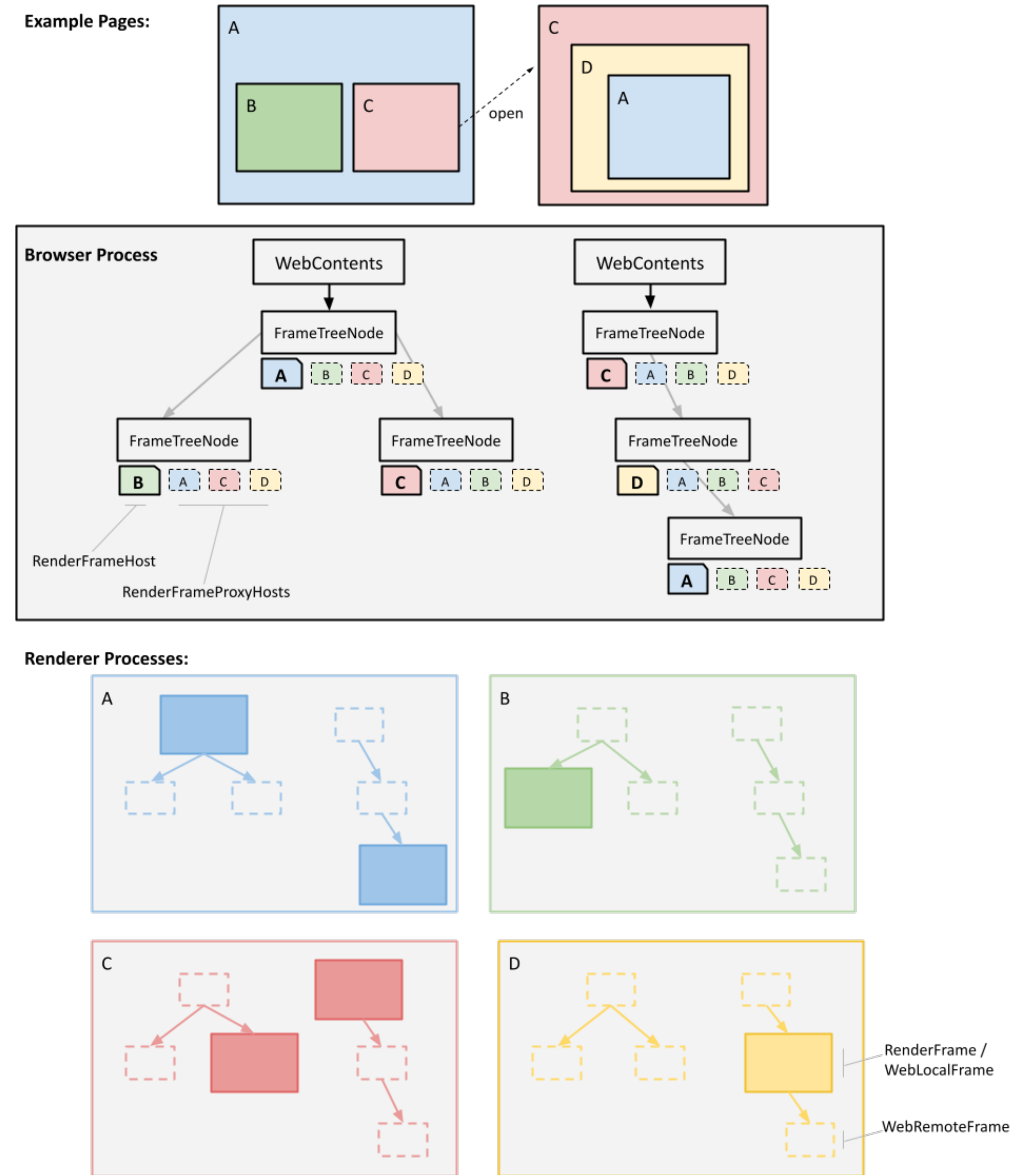
Browser execution model

- Browsers use an inordinate amount of processes to handle modern websites
- Each browser window / tab...
 - Loads and renders content
 - Parses HTML and runs JavaScript
 - Fetches subresources (e.g., images, CSS, JavaScript)
 - Responds to events like onClick, onMouseover, onLoad, onTimeout



HTML 🤝 Advertising

- The ad ecosystem is largely delivered via the **iframe** — *a visible division of screen real-estate*
- Why use frames?
 - Browser provides **isolation** based on frame — each frame gets its own rendering process, separation of code memory, etc.
 - Delegate screen area to content from another source (e.g., ads)



Where is the iframe that holds the ad?

Replay

Learn More

Advertisement

Sponsored Video

Watch to learn more

BY ADVERTISING PARTNER

Learn More

Ad Feedback

CNN

US

World

Politics

Business

Health

Entertainment

Underscored

Style

Travel

More

Watch

Listen

Subscribe

Sign in

Q&As: James Talarico

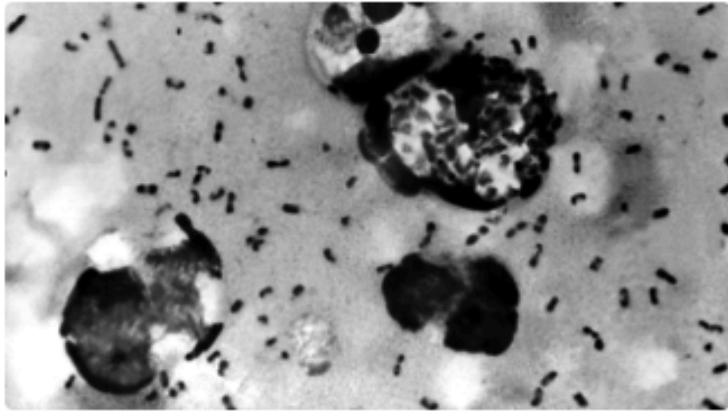
Midterms

Trending: Pneumonic plague

Estate sale find

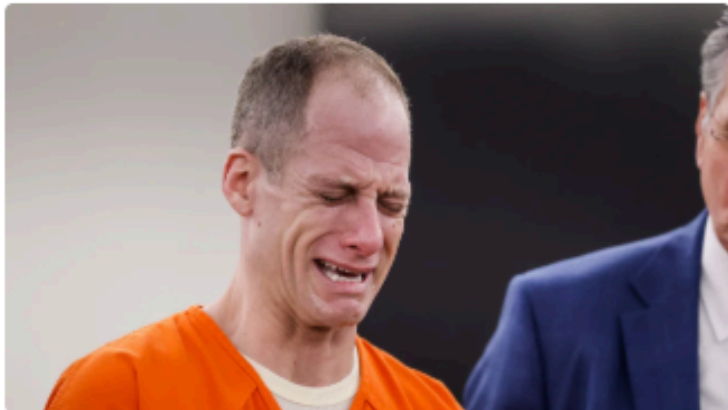
Gillian Anderson

CNN Underscored: Amazon Prime Day



What is pneumonic plague and how dangerous is it?

Researcher at Russian plague lab dies of 'unknown' infection



Caleb Flynn's daughters send

'A five-alarm fire' confronts President Trump in campaign blitz



Brendan Smialowski/AFP/Getty Images

The president is looking for a safe harbor – and to fire up friendly faces – in the latest stop on his red-state October flurry



Catch up on today's headlines



First-ever evidence of a second-generation planet detected around dead star

48

Where is the iframe that holds the ad?

Replay

Learn More

Sponsored Video

Watch to learn more

BY ADVERTISING PARTNER

Learn More

Advertisement

Ad Feedback

CNN

US

World

Politics

Business

Health

Entertainment

Underscored

Style

Travel

More

Watch

Listen

Subscribe

Sign in

Q&As: James Talarico

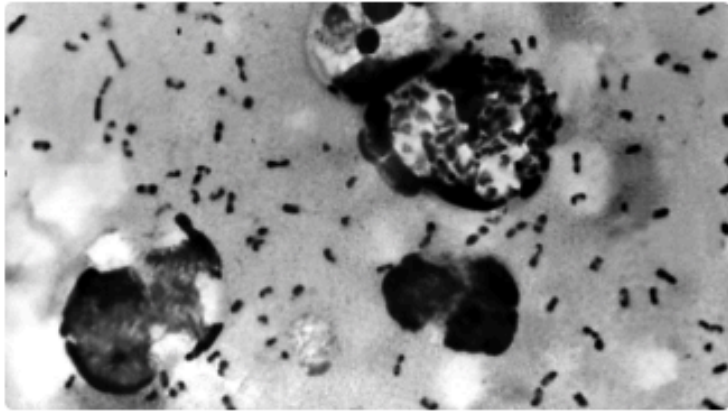
Midterms

Trending: Pneumonic plague

Estate sale find

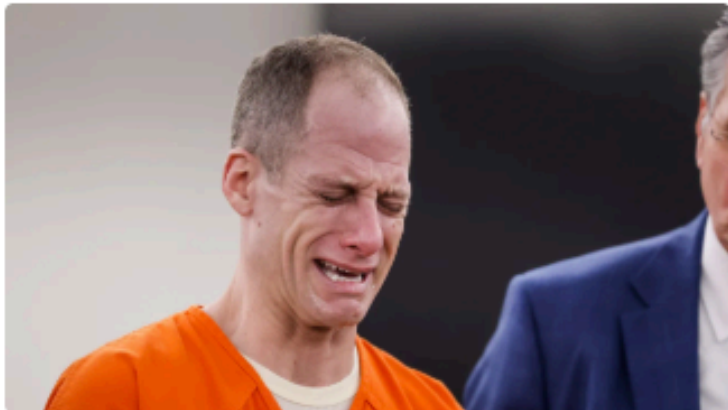
Gillian Anderson

CNN Underscored: Amazon Prime Day



What is pneumonic plague and how dangerous is it?

Researcher at Russian plague lab dies of 'unknown' infection

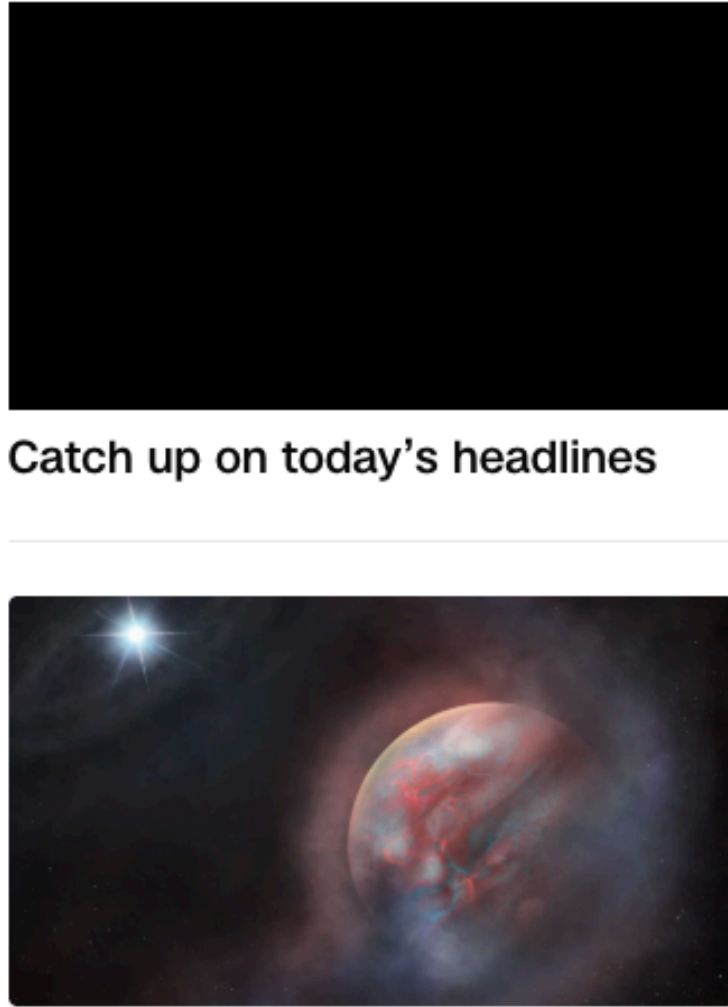


Caleb Flynn's daughters send



'A five-alarm fire' confronts President Trump in campaign blitz

The president is looking for a safe harbor – and to fire up friendly faces – in the latest stop on his red-state October flurry



Catch up on today's headlines

First-ever evidence of a second-generation planet detected around dead star

49

```
<iframe
  id="google_ads_iframe_/8663477/CNN/homepage/landing_4"
  name="google_ads_iframe_/8663477/CNN/homepage/landing_4"
  title="3rd party ad content"
  width="970"
  height="250"
  scrolling="no"
  marginwidth="0"
  marginheight="0"
  frameborder="0"
  aria-label="Advertisement"
  tabindex="0"
  allow="private-state-token-redemption"
  sandbox="allow-forms allow-pointer-lock allow-popups
          allow-popups-to-escape-sandbox allow-same-origin
          allow-scripts allow-top-navigation-by-user-activation
          allow-presentation"
  data-load-complete="true"
  style="border: 0px; vertical-align: bottom;"
  data-google-container-id="5">
  ...
</iframe>
```



```
<iframe
  id="google_ads_iframe_/8663477/CNN/homepage/landing_4"
  name="google_ads_iframe_/8663477/CNN/homepage/landing_4"
  title="3rd party ad content"
  width="970"
  height="250"
  scrolling="no"
  marginwidth="0"
  marginheight="0"
  frameborder="0"
  aria-label="Advertisement"
```

Who put the Google <iframe> on cnn.com?

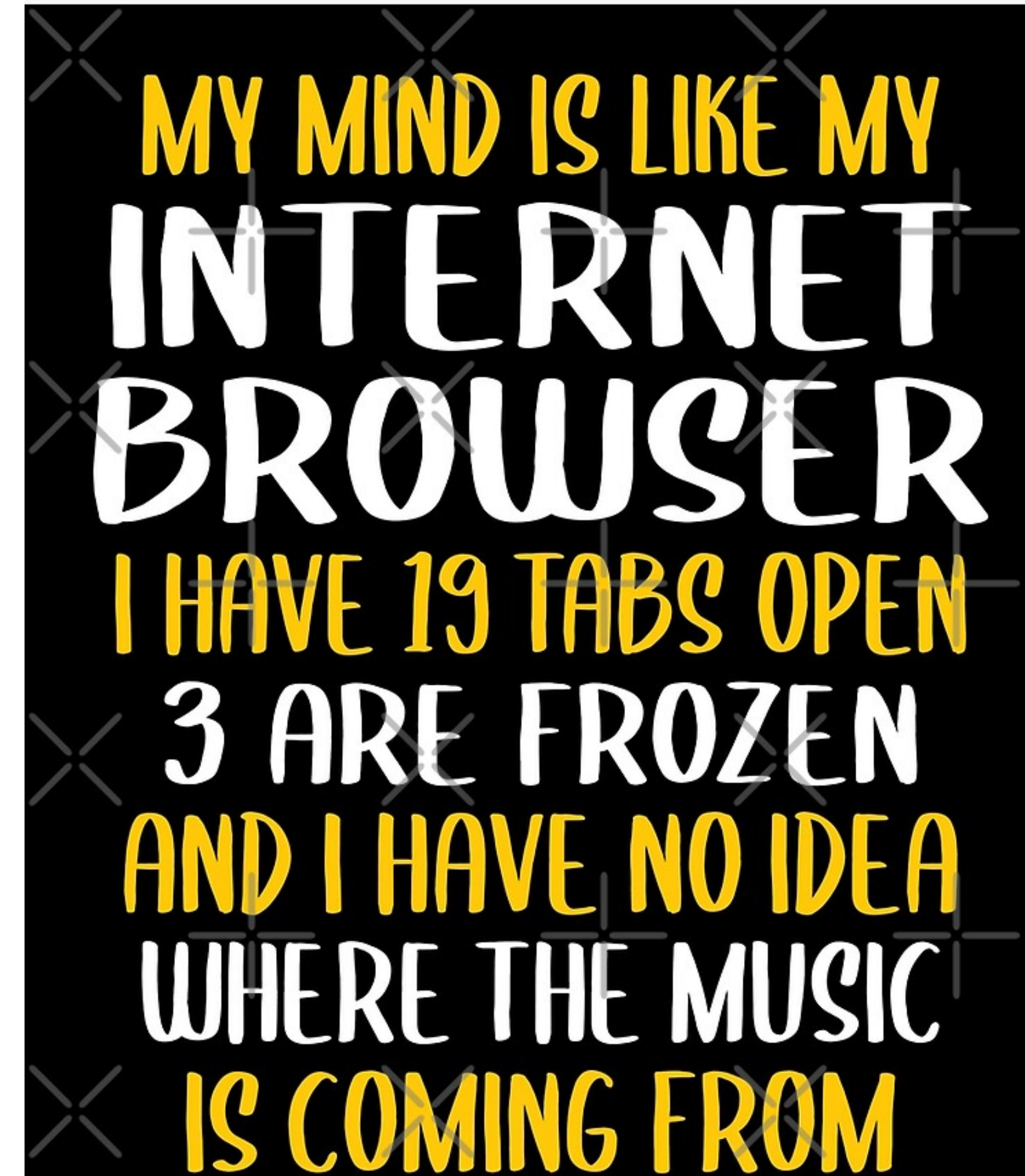
```
<iframe
  id="google_ads_iframe_/8663477/CNN/homepage/landing_4"
  name="google_ads_iframe_/8663477/CNN/homepage/landing_4"
  title="3rd party ad content"
  width="970"
  height="250"
  scrolling="no"
  marginwidth="0"
  marginheight="0"
  frameborder="0"
  aria-label="Advertisement"
```

Who put the Google <iframe> on cnn.com?



Browsers do lots of things...

- With a group, get together and answer the following questions:
 - What are some responsibilities of web browsers?
 - In what ways do browsers protect users or protect user data?



MY MIND IS LIKE MY
INTERNET
BROWSER
I HAVE 19 TABS OPEN
3 ARE FROZEN
AND I HAVE NO IDEA
WHERE THE MUSIC
IS COMING FROM

A web of lies

- **Web developers** program *servers* and *webpages* that serve content **and** direct the browser to conduct browserly duties
 - “Render this page”
 - “Run this code”
 - “Load this ad from this server over here”

A web of lies

- **Web developers** program *servers* and *webpages* that serve content **and** direct the browser to conduct browserly duties
 - “Render this page”
 - “Run this code”
 - “Load this ad from this server over here”
- It’s the browser’s job to do the bidding of the **web developer... not the user.**
 - So what on earth are developers putting on webpages?

Modern websites run a lot of stuff...

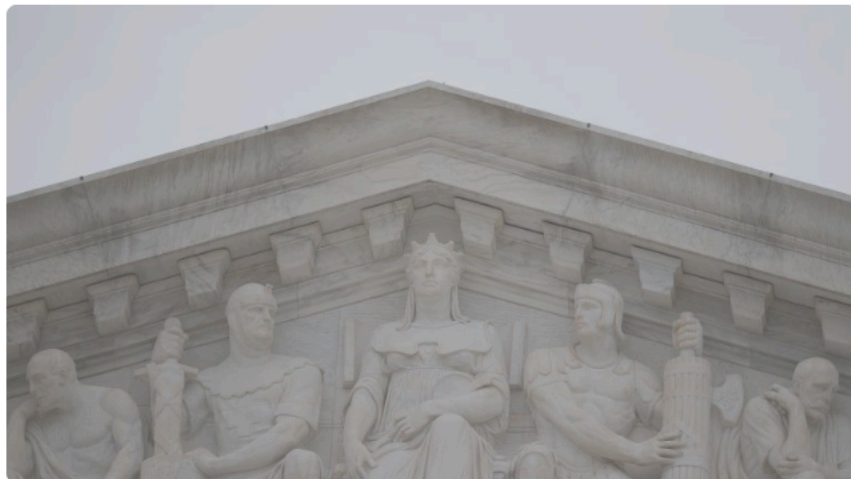
How many resources does this page load?



USWorldPoliticsBusinessHealthEntertainmentUnderscoredMore

● WatchSubscribeSign in

Live Updates: Trump administration | Trending: Epstein files | Nancy Guthrie disappearance | Rep. Maxine Waters | Nike probe | Drake Maye



Supreme Court lets California use new Democrat-friendly congressional map

ANALYSIS



Secluded location and intense scrutiny put pressure on investigators in Nancy Guthrie's disappearance

Sheriff probes possible ransom notes in Nancy Guthrie's disappearance, while

https://www.cnn.com/2026/02/04/politics/supreme-court-california-redistricting-map

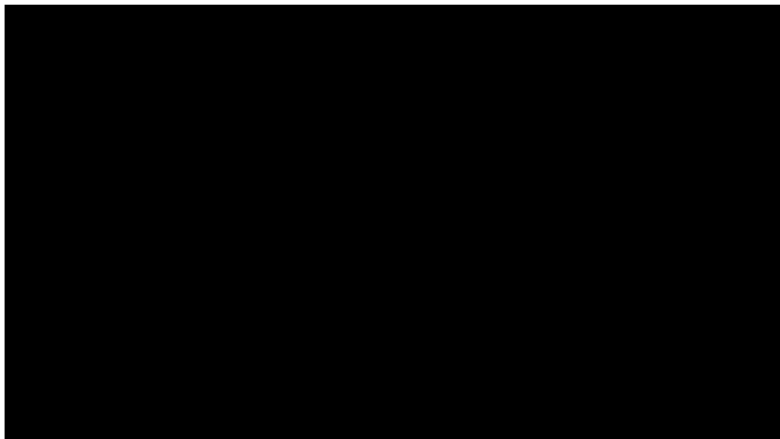
'This job sucks,' Trump administration attorney tells judge amid crush of immigration cases



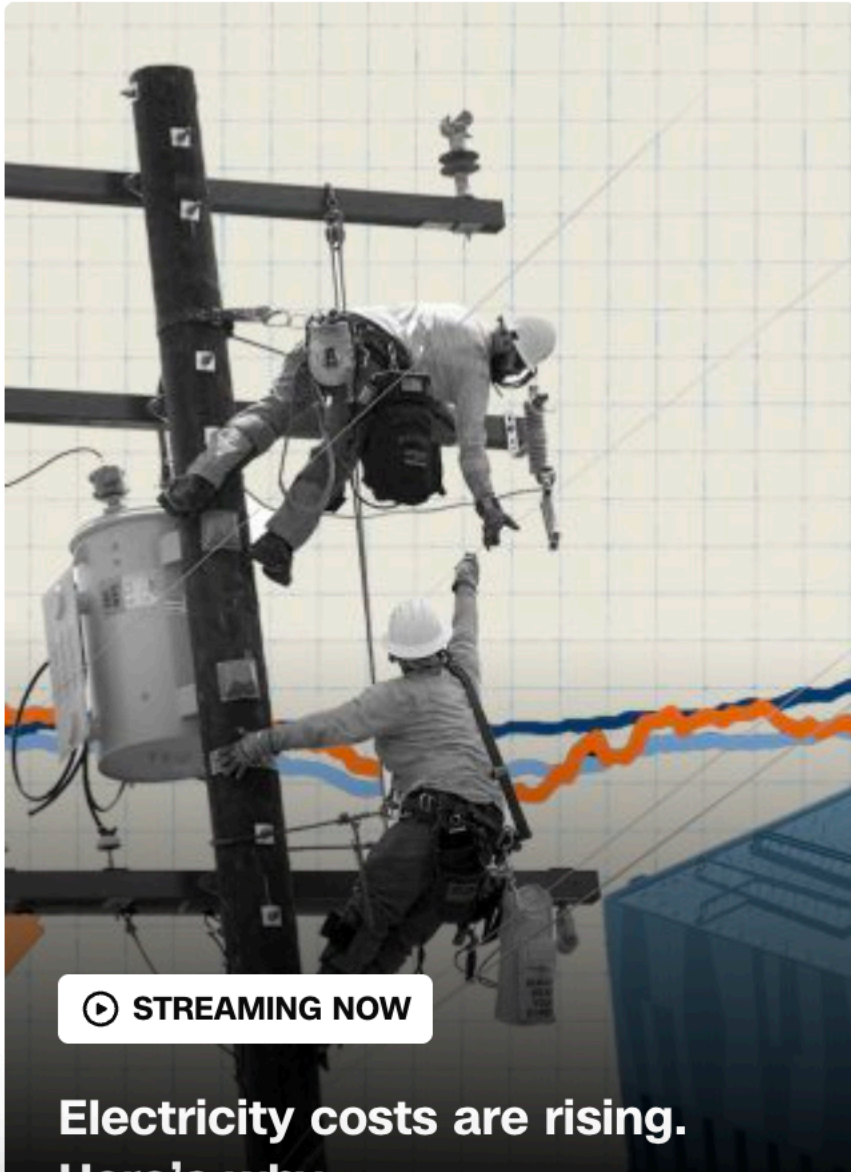
Her comments offer a rare look under the hood of Operation Metro Surge in Minnesota, which officials announced would be partially scaled back

Live Updates: Homan: DHS withdrawing 700 personnel from MN 'immediately'

Analysis: How bad was Alex Pretti's killing for the Trump administration? New data tells us



Catch up on today's headlines



Streaming Now

Electricity costs are rising.

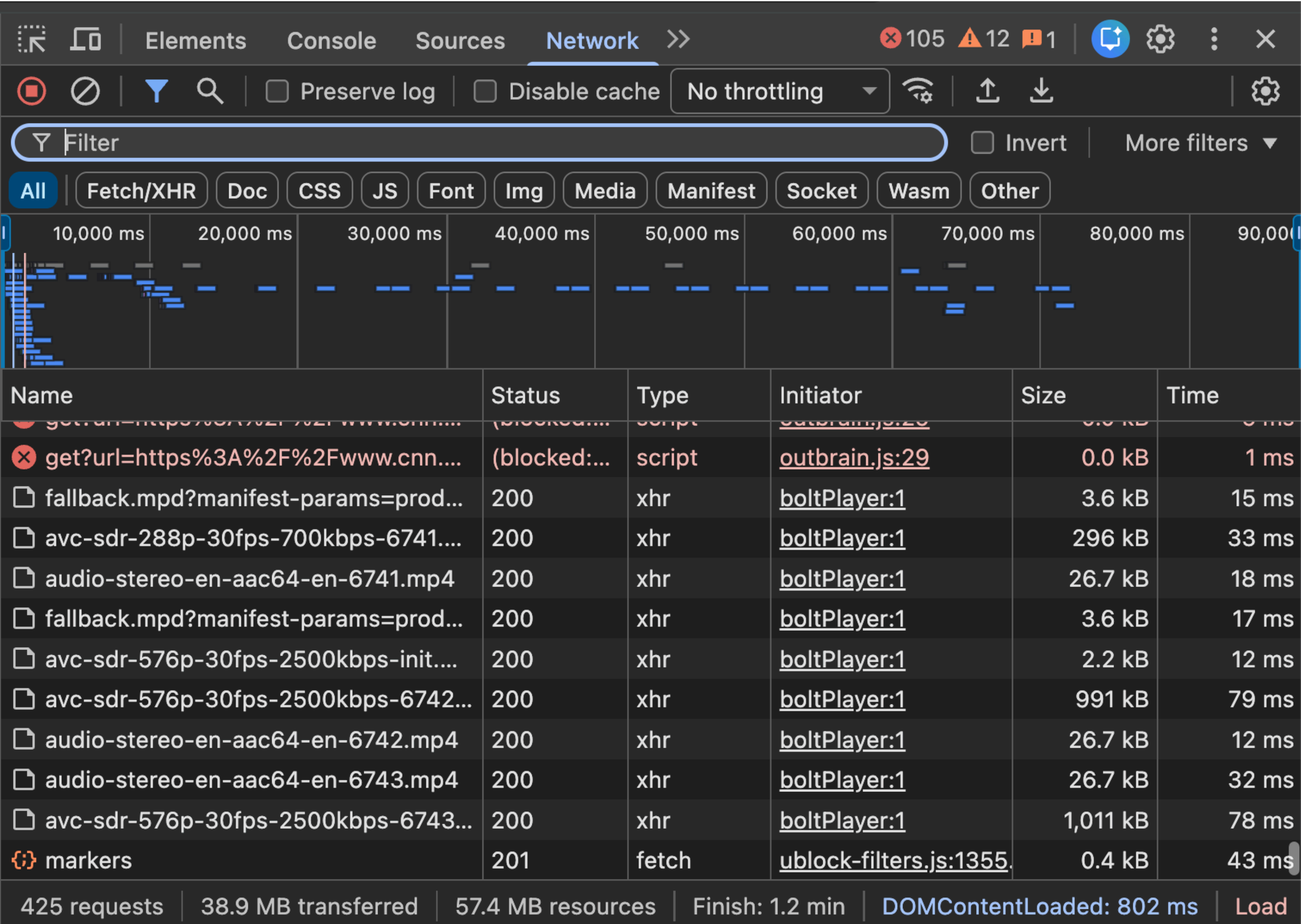
56

Modern websites run a lot of stuff...

How many resources does this page load?

After ~1min...
425 requests!

Only about 40% come from cnn.com... so...?



Modern websites

Third Party Resources

- Modern websites rely on many different types of *third-party resources* to provide services to keep their websites functional (in contrast to first-party)
- Third party resources are ones served by external parties
 - If you are on cnn.com, any resource served from a domain that is NOT cnn.com (e.g., doubleclick.com, google-analytics.com) is considered a third-party
- These resources can be many things...
 - Images, CSS, JSON, and most terrifyingly, *JavaScript*

Browser protections

- In general, the browser protects users through something called the *same-origin policy*
 - Basic gist is browsers make a delineation between **first-party interactions** and **third-party interactions**
- What are “first-party” interactions?

Browser protections

- In general, the browser protects users through something called the *same-origin policy*
 - Basic gist is browsers make a delineation between **first-party interactions** and **third-party interactions**
- What are “first-party” interactions?
 - Browser interactions between the same “origin” — loosely, domain.
 - E.g., loading an image from kumarde.com/headshot.jpg when visiting kumarde.com
 - First-party interactions are generally “trusted,” in contrast to third-party interactions which are “untrusted”

JAVASCRIPT CAN HURT YOU

- Many tutorials on the web have you include things like the following:

```
<script src="jquery.com/min.js"></script>
```


JAVASCRIPT CAN HURT YOU

- Many tutorials on the web have you include things like the following:

```
<script src="jquery.com/min.js"></script>
```

- You should know that loading JavaScript like this **gives this script first-party access to your page**
- This means that the JS can...
 - Read your cookies
 - Modify any variables you store on the client
 - Read most browser properties
 - **And send this data anywhere it wants on the web. Proceed with caution!**

Modern Websites

Third Party Resources

- What are some things that third-party resources might be used for?

Modern Websites

Third Party Resources

- What are some things that third-party resources might be used for?
 - Functionality (e.g., jQuery, CDNs, UI things)
 - Analytics (e.g., Google Analytics)
 - Social Media (e.g., FB like button)
 - Web Tracking (e.g., FB pixels) —> mostly to enable advertising

Modern Websites

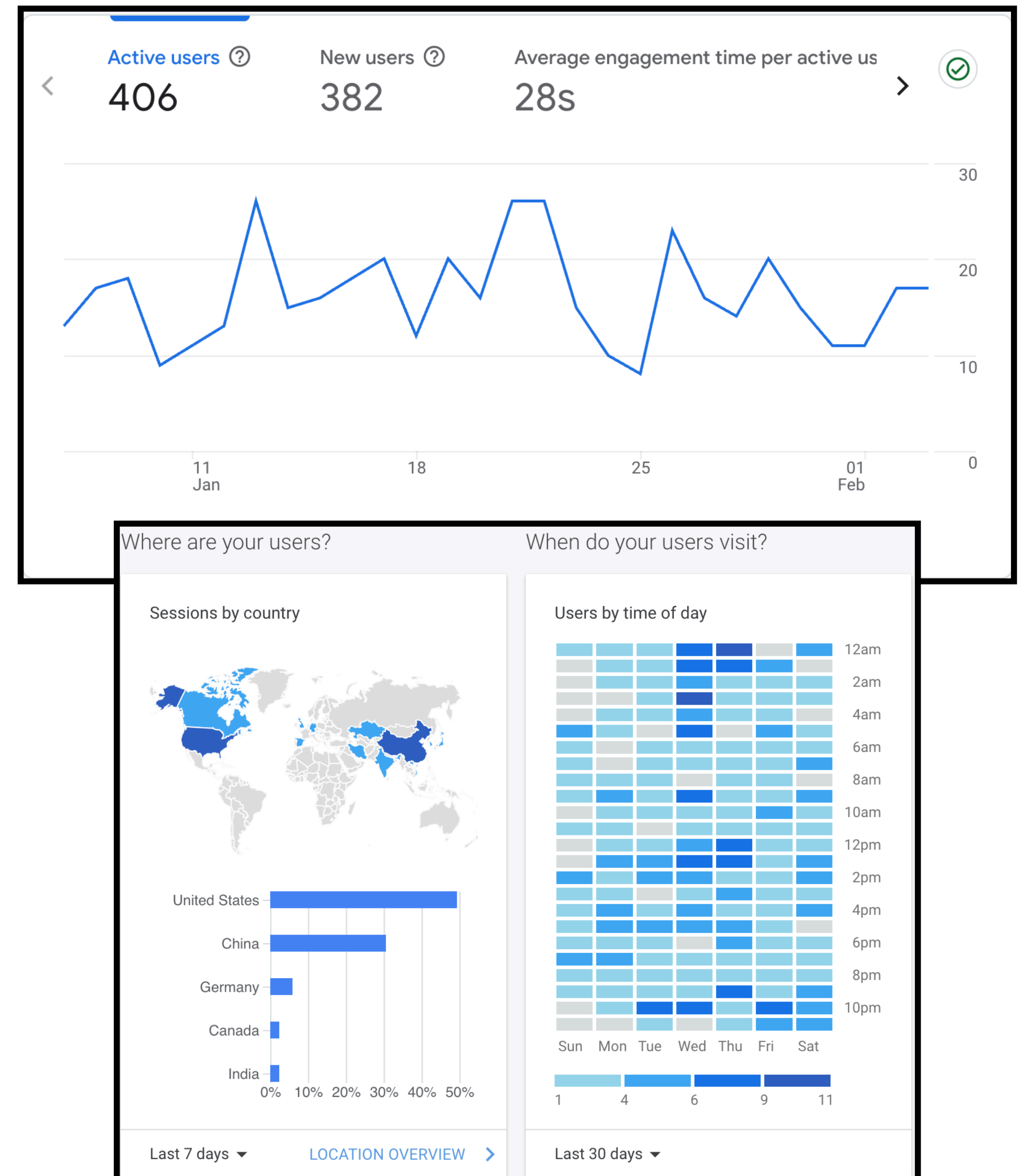
Third Party Resources

- What are some things that third-party resources might be used for?
 - Functionality (e.g., jQuery, CDNs, UI things)
 - **Analytics (e.g., Google Analytics)**
 - **Social Media (e.g., FB like button)**
 - **Web Tracking (e.g., FB pixels) —> mostly to enable advertising**

Modern Websites

Analytics

- Many websites use analytics to continue to improve their services
- Google analytics appears on 70% of sites
- Answers a number of questions
 - Where are clients coming from?
 - How long are they on the page?
 - What devices are they using?



Modern Websites

How does Google analytics work?

```
<!-- Google tag (gtag.js) -->
<script async src="https://www.googletagmanager.com/gtag/js?id=G-8YLEB9GP4Y"></script>
<script>
  window.dataLayer = window.dataLayer || [];
  function gtag(){dataLayer.push(arguments);}
  gtag('js', new Date());

  gtag('config', '<YOUR CODE HERE>');
</script>
```

Modern Websites

How does Google analytics work?

```
<!-- Google tag (gtag.js) -->  
<script async src="https://www.googletagmanager.com/gtag/js?id=G-8YLEB9GP4Y"></script>  
<script>  
  window.dataLayer = window.dataLayer || [];  
  function gtag(){dataLayer.push(arguments);}  
  gtag('js', new Date());  
  
  gtag('config', '<YOUR CODE HERE>');  
</script>
```

- Google Analytics loads a script on the page — allowing it to **monitor everything** and send data back
- But... how does it know all that stuff about those visitors?

Cookies

Cookie Priors

- What do you know about cookies?

Cookie Basics

- What is a cookie?

Cookie Basics

- What is a cookie?
 - “A small piece of data created by a web server and stored on a user’s device by their web browser.”
- In other words, a cookie is a way to turn a **stateless** ecosystem into a **stateful** one
 - What does it mean for something to be **stateless**?
- Why do we have cookies?

Cookie Basics

- What is a cookie?
 - “A small piece of data created by a web server and stored on a user’s device by their web browser.”
- In other words, a cookie is a way to turn a **stateless** ecosystem into a **stateful** one
 - What does it mean for something to be **stateless**?
- Why do we have cookies?
 - Sessions, personalization, and these days, **tracking**

A brief history of cookies

- Cookies have been around for a **while...** since 1997 (so, basically since the first web browsers)
- Even in the early specs, privacy and security was discussed... but unopinionated on how
 - "This specification requires that a user agent (browser) give the user control over a [privacy] intrusion... although the **interface is left unspecified.**"
- Cookie spec has been updated many times since then (most recently in 2011)

RFC 2109: HTTP State Management Mechanism

cookies

D. Kristol, L. Montulli

HISTORIC

Rate this RFC

Subscribe

Add to Set

This RFC is now obsolete, see [RFC 2965](#).

Network Working Group

Request for Comments: 2109

Category: Standards Track

D. Kristol

Bell Laboratories, Lucent Technologies

L. Montulli

Netscape Communications

February 1997

RFC 6265: HTTP State Management Mechanism

cookies

A. Barth

PROPOSED STANDARD

Rate this RFC

Subscribe

Add to Set

Internet Engineering Task Force (IETF)

Request for Comments: 6265

Obsoletes: [2965](#)

Category: Standards Track

ISSN: 2070-1721

A. Barth

U.C. Berkeley

April 2011

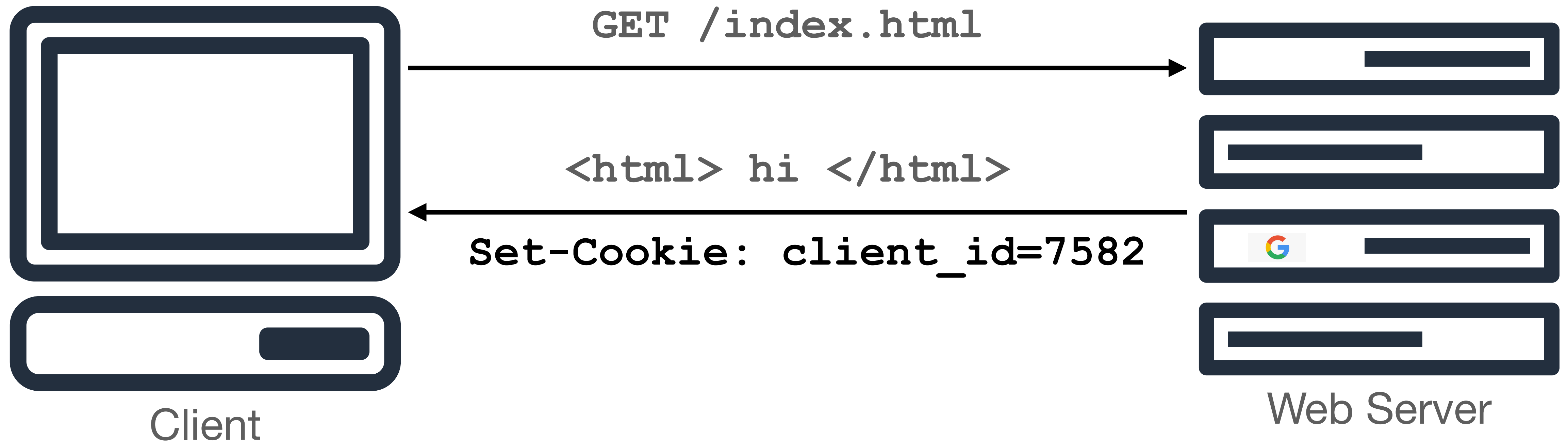
How do web cookies work?



How do web cookies work?



How do web cookies work?



How do web cookies work?



Client

The web client
(browser) stores the
cookie value in a
local file.

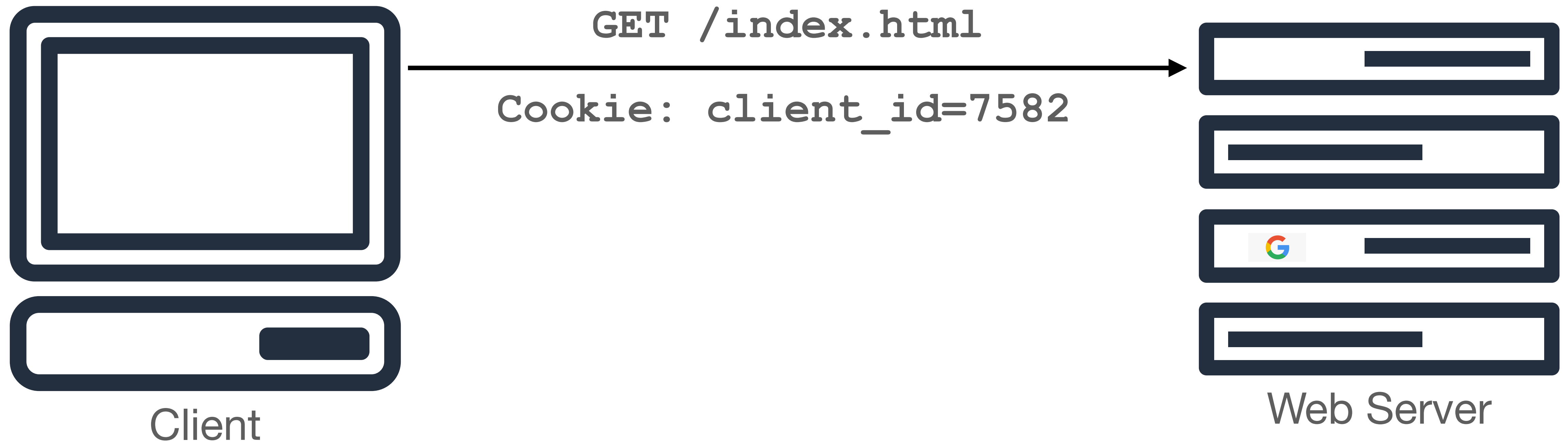


Web Server

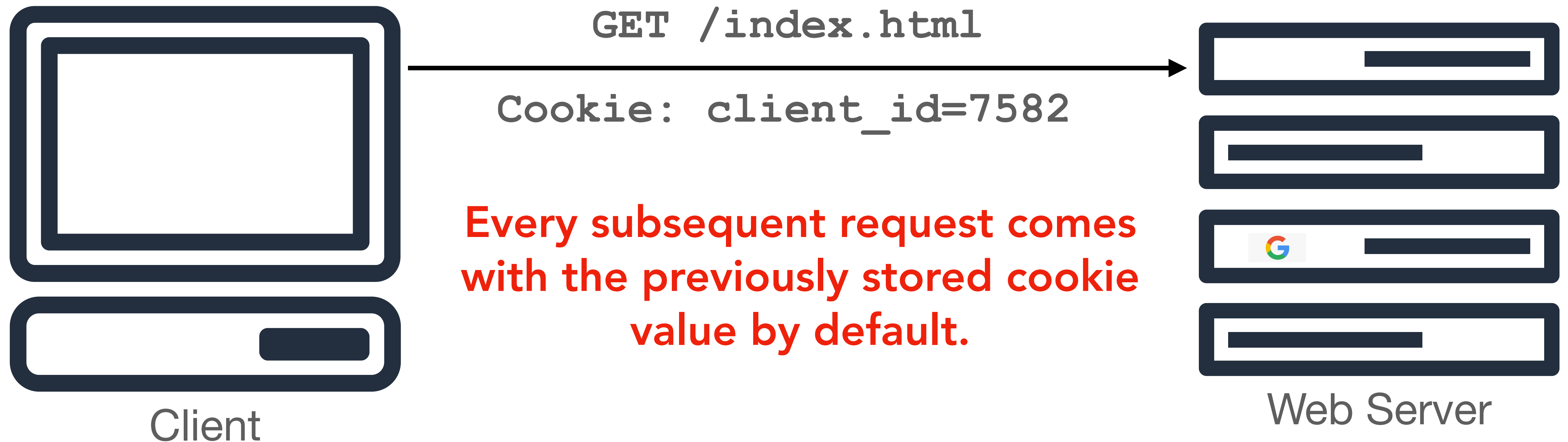
How do web cookies work?



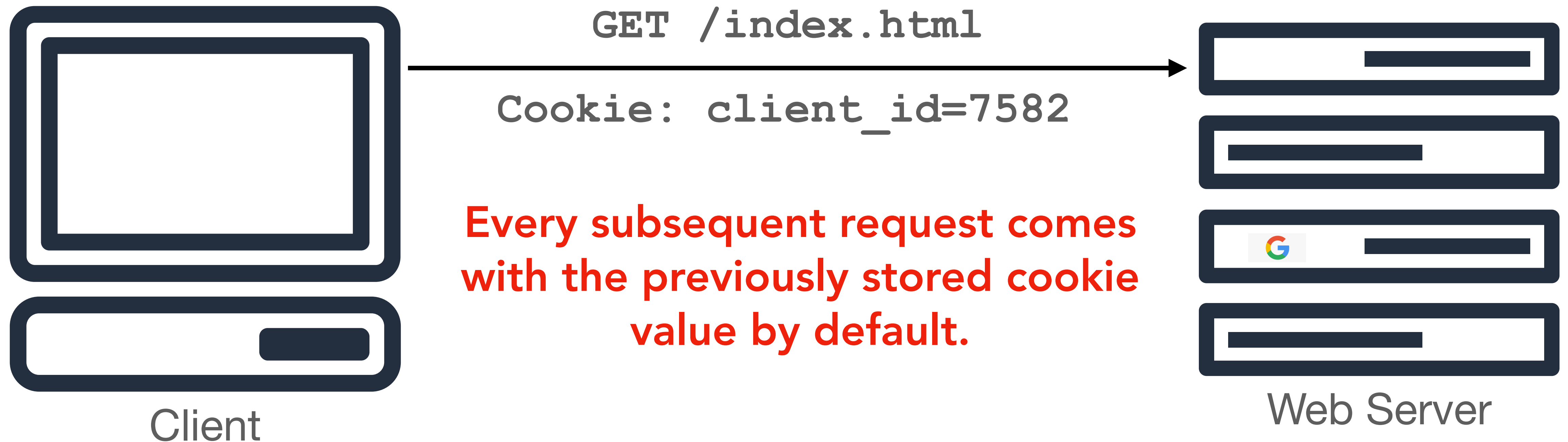
How do web cookies work?



How do web cookies work?



How do web cookies work?



Why might this be a good idea?

How do web cookies work?

- **State** is very useful for making applications work! Without state, we wouldn't know anything about the user...
- Imagine a world *without* some kind of client-side state keeping.
 - How would you implement authenticated actions?

How do web cookies work?

- **State** is very useful for making applications work! Without state, we wouldn't know anything about the user...
- Imagine a world *without* some kind of client-side state keeping.
 - How would you implement authenticated actions?
 - The client would have to authenticate itself *every time*... which might be challenging from the perspective of a user
- **Cookies are a fundamental building block of the web!**

Cookies for everyone!

- Think about these with people around you (all yes/no)
 - Let's say a website `foo.com` sets a cookie called `client_id`. **Should...**
 - The browser send the cookie to subsequent requests to `foo.com`?
 - The browser send the cookie to `foo.net`?
 - The browser send the cookie to `foo.gov`?
 - The browser send the cookie to `test.foo.com`?
 - The browser send the cookie to `foo.com/test`?

Cookie Scoping

- How cookies are shared are ultimately **scoped** by the server, by several properties:
 - Domain
 - Path
 - Secure
 - How they're accessed
 - Time

Cookie Scoping

- How cookies are shared are ultimately **scoped** by the server, by several properties:
 - Domain — Set-Cookie: `client_id=7582, Domain=example.com`
 - Path
 - Secure
 - How they're accessed
 - Time

Cookies and Domains

- What domains can a web server set cookies for?
- domain: any domain-suffix of URL-hostname, except "public suffixes"
 - host = "login.site.com," can set login.site.com, site.com, but **not** .com

PUBLIC SUFFIX LIST

[LEARN MORE](#) | [THE LIST](#) | [SUBMIT AMENDMENTS](#)

A "public suffix" is one under which Internet users can (or historically could) directly register names. Some examples of public suffixes are com, co.uk and pvt.k12.ma.us. The Public Suffix List is a list of all known public suffixes.

The Public Suffix List is an initiative of [Mozilla](#), but is maintained as a community resource. It is available for use in any software, but was originally created to meet the needs of browser manufacturers. It allows browsers to, for example:

- Avoid privacy-damaging "supercookies" being set for high-level domain name suffixes
- Highlight the most important part of a domain name in the user interface
- Accurately sort history entries by site

We maintain a [fuller \(although not exhaustive\) list](#) of what people are using it for. If you are using it for something else, you are encouraged to tell us, because it helps us to assess the potential impact of changes. For that, you can use the [psl-discuss](#) mailing list, where we consider issues related to the maintenance, format and semantics of the list. Note: please do not use this mailing list to [request amendments](#) to the PSL's data.

It is in the interest of Internet registries to see that their section of the list is up to date. If it is not, their customers may have trouble setting cookies, or data about their sites may display sub-optimally. So we encourage them to maintain their section of the list by [submitting amendments](#).

What do you think the default here is?

Cookies and Domains

- What domains can a web server set cookies for?
- domain: any domain-suffix of URL-hostname, except "public suffixes"
 - host = "login.site.com," can set login.site.com, site.com, but **not** .com

PUBLIC SUFFIX LIST

[LEARN MORE](#) | [THE LIST](#) | [SUBMIT AMENDMENTS](#)

A "public suffix" is one under which Internet users can (or historically could) directly register names. Some examples of public suffixes are com, co.uk and pvt.k12.ma.us. The Public Suffix List is a list of all known public suffixes.

The Public Suffix List is an initiative of [Mozilla](#), but is maintained as a community resource. It is available for use in any software, but was originally created to meet the needs of browser manufacturers. It allows browsers to, for example:

- Avoid privacy-damaging "supercookies" being set for high-level domain name suffixes
- Highlight the most important part of a domain name in the user interface
- Accurately sort history entries by site

We maintain a [fuller \(although not exhaustive\) list](#) of what people are using it for. If you are using it for something else, you are encouraged to tell us, because it helps us to assess the potential impact of changes. For that, you can use the [psl-discuss](#) mailing list, where we consider issues related to the maintenance, format and semantics of the list. Note: please do not use this mailing list to [request amendments](#) to the PSL's data.

It is in the interest of Internet registries to see that their section of the list is up to date. If it is not, their customers may have trouble setting cookies, or data about their sites may display sub-optimally. So we encourage them to maintain their section of the list by [submitting amendments](#).

What do you think the default here is?

Default is **most restrictive!**

Cookie Scoping

- How cookies are shared are ultimately **scoped** by the server, by several properties:
 - Domain — Set-Cookie: `client_id=7582; Domain=example.com`
 - Path — Set-Cookie: `client_id=7582; Path=/docs`
 - Secure
 - How they're accessed
 - Time

Cookies and Paths

- The `Path` sets the topmost path that can read the cookie
- E.g., `"/` is the most permissive, `"/you/cant/read/this"` is much more restrictive
- You will use `Path` in part 2!
- **What do you think the default here is?**



Cookies and Paths

- The `Path` sets the topmost path that can read the cookie
 - E.g., `"/` is the most permissive, `"/you/cant/read/this"` is much more restrictive
 - You will use `Path` in part 2!
- **What do you think the default here is?**
 - Set to the "topmost level from trailing slash..."
 - `/you/cant` —> `Path=/you`
 - `/you/cant/` —> `Path=/you/cant/`



Cookie Scoping

- How cookies are shared are ultimately **scoped** by the server, by several properties:
 - Domain — Set-Cookie: `client_id=7582; Domain=example.com`
 - Path — Set-Cookie: `client_id=7582; Path=/docs`
 - Secure — Set-Cookie: `client_id=7582; Secure`
 - How they're accessed
 - Time

Cookie Scoping

- How cookies are shared are ultimately **scoped** by the server, by several properties:
 - Domain — Set-Cookie: `client_id=7582; Domain=example.com`
 - Path — Set-Cookie: `client_id=7582; Path=/docs`
 - Secure — Set-Cookie: `client_id=7582; Secure`
 - How they're accessed — Set-Cookie: `client_id=7582; HttpOnly`
 - Time

Cookie Scoping

- How cookies are shared are ultimately **scoped** by the server, by several properties:
 - Domain — Set-Cookie: `client_id=7582; Domain=example.com`
 - Path — Set-Cookie: `client_id=7582; Path=/docs`
 - Secure — Set-Cookie: `client_id=7582; Secure`
 - How they're accessed — Set-Cookie: `client_id=7582; HttpOnly`
 - Time — Set-Cookie: `client_id=7582; Max-Age=3600`

Cookies by the Expiration Date

- Session cookies
 - Expiration property is not set
 - Exist *only* during current browser session
 - Deleted when your browser is shut down
 - Examples?
- Persistent cookies
 - Saved until server-defined expiration time
 - Examples?



How do we decide to send cookies?

- Browser sends all cookies in a URL's scope:
 - Cookie's domain is a domain suffix of URL's domain
 - Cookie's path is a **prefix** of the URL path

How do we decide to send cookies?

Cookie 1:

name = mycookie

value = value

domain = login.site.com

path = /

Cookie 2:

name = mycookie2

value = value

domain = site.com

path = /

Cookie 3:

name = mycookie3

value = value

domain = site.com

path = /my/home

How do we decide to send cookies?

Cookie 1:

name = mycookie

value = value

domain = login.site.com

path = /

Cookie 2:

name = mycookie2

value = value

domain = site.com

path = /

Cookie 3:

name = mycookie3

value = value

domain = site.com

path = /my/home

Request to URL:	Cookie 1	Cookie 2	Cookie 3
<u>checkout.site.com</u>			
<u>login.site.com</u>			
<u>login.site.com/my/home</u>			
<u>site.com/my</u>			

How do we decide to send cookies?

Cookie 1:

name = mycookie

value = value

domain = login.site.com

path = /

Cookie 2:

name = mycookie2

value = value

domain = site.com

path = /

Cookie 3:

name = mycookie3

value = value

domain = site.com

path = /my/home

Request to URL:	Cookie 1	Cookie 2	Cookie 3
<u>checkout.site.com</u>	No	Yes	No
<u>login.site.com</u>			
<u>login.site.com/my/home</u>			
<u>site.com/my</u>			

How do we decide to send cookies?

Cookie 1:
name = mycookie
value = value
domain = login.site.com
path = /

Cookie 2:
name = mycookie2
value = value
domain = site.com
path = /

Cookie 3:
name = mycookie3
value = value
domain = site.com
path = /my/home

Request to URL:	Cookie 1	Cookie 2	Cookie 3
<u>checkout.site.com</u>	No	Yes	No
<u>login.site.com</u>	Yes	Yes	No
<u>login.site.com/my/home</u>			
<u>site.com/my</u>			

How do we decide to send cookies?

Cookie 1:

name = mycookie

value = value

domain = login.site.com

path = /

Cookie 2:

name = mycookie2

value = value

domain = site.com

path = /

Cookie 3:

name = mycookie3

value = value

domain = site.com

path = /my/home

Request to URL:	Cookie 1	Cookie 2	Cookie 3
<u>checkout.site.com</u>	No	Yes	No
<u>login.site.com</u>	Yes	Yes	No
<u>login.site.com/my/home</u>	Yes	Yes	Yes
<u>site.com/my</u>			

How do we decide to send cookies?

Cookie 1:
name = mycookie
value = value
domain = login.site.com
path = /

Cookie 2:
name = mycookie2
value = value
domain = site.com
path = /

Cookie 3:
name = mycookie3
value = value
domain = site.com
path = /my/home

Request to URL:	Cookie 1	Cookie 2	Cookie 3
<u>checkout.site.com</u>	No	Yes	No
<u>login.site.com</u>	Yes	Yes	No
<u>login.site.com/my/home</u>	Yes	Yes	Yes
<u>site.com/my</u>	No	Yes	No

Lots of other properties...

- `SameSite` (primarily a defense against a CSRF attack — see CSE 127)
- `Partitioned` (we'll talk about this next time!)
- Thought experiment: **when a server gets a request with a cookie, what does it see?**

Lots of other properties...

- `SameSite` (primarily a defense against a CSRF attack — see CSE 127)
- `Partitioned` (we'll talk about this next time!)
- Thought experiment: **when a server gets a request with a cookie, what does it see?**
 - Only the cookie value... none of the properties. Why might that be a problem?

Lots of other properties...

- `SameSite` (primarily a defense against a CSRF attack — see CSE 127)
- `Partitioned` (we'll talk about this next time!)
- Thought experiment: **when a server gets a request with a cookie, what does it see?**
 - Only the cookie value... none of the properties. Why might that be a problem?
- Cookie prefixes to the rescue!
 - E.g., Prepending your cookie name with `__Host-` tells the browser to do something special, and the server knows its original intention

TL;DR — Cookies are heavily guarded

- The browser protects cookies, and follows a very tight specification
- Cookies are well protected by server side specification too
- **So... how do they enable tracking?**

Third-Party Tracking

- How does a company actually *track* you on the web using cookies? Seems like there's a lot of protections?

Third-Party Tracking

- How does a company actually *track* you on the web using cookies? Seems like there's a lot of protections?



Client

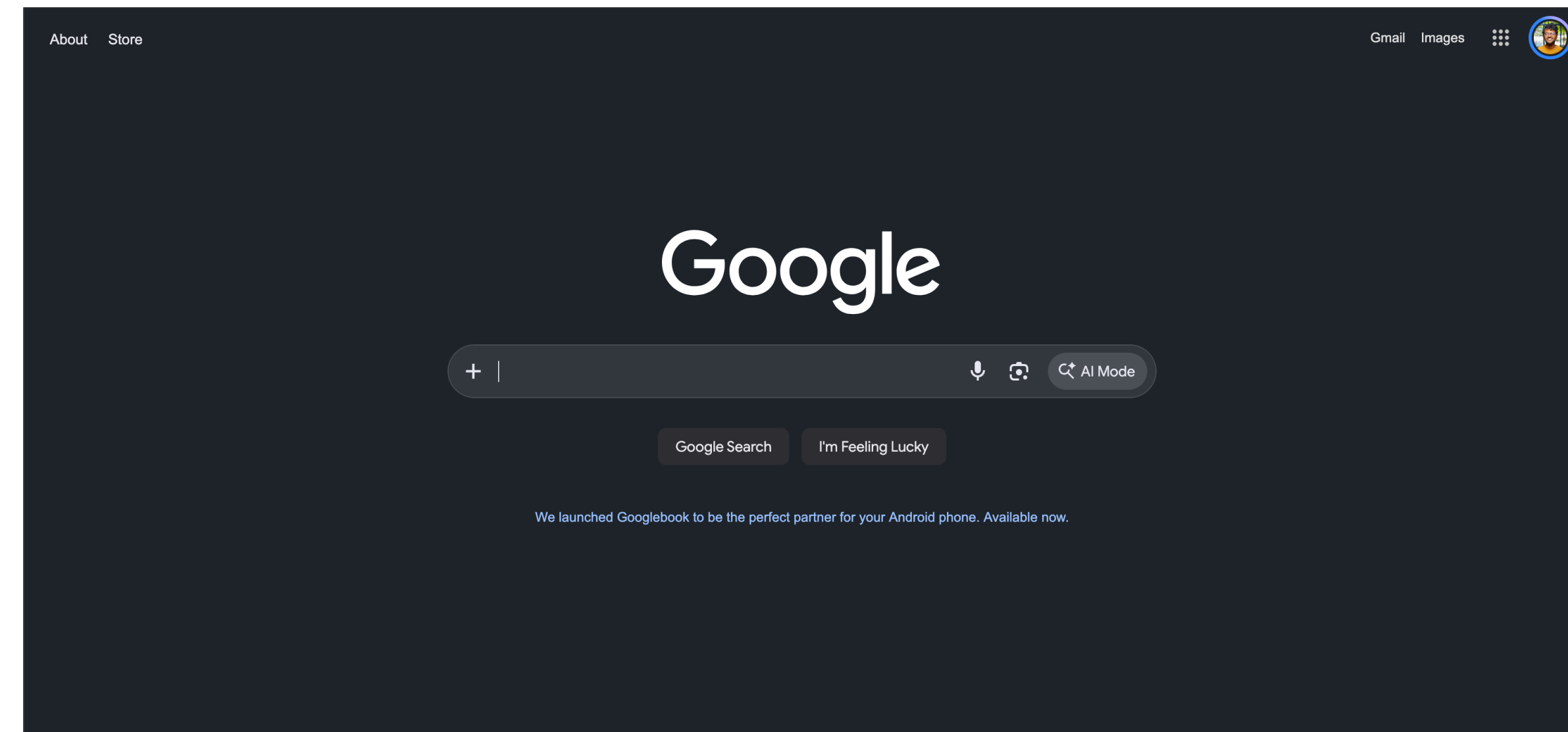
Third-Party Tracking

- How does a company actually *track* you on the web using cookies? Seems like there's a lot of protections?



Client

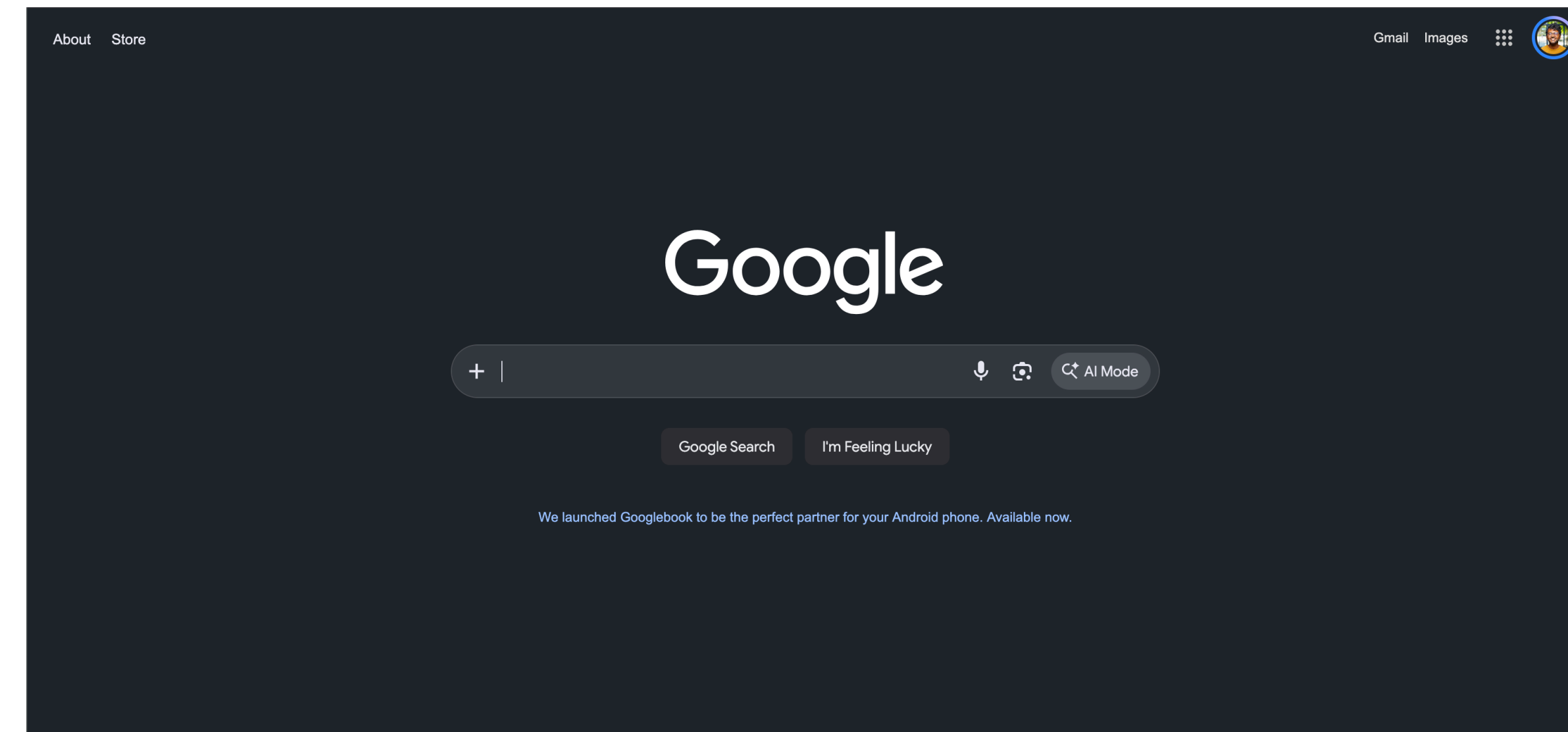
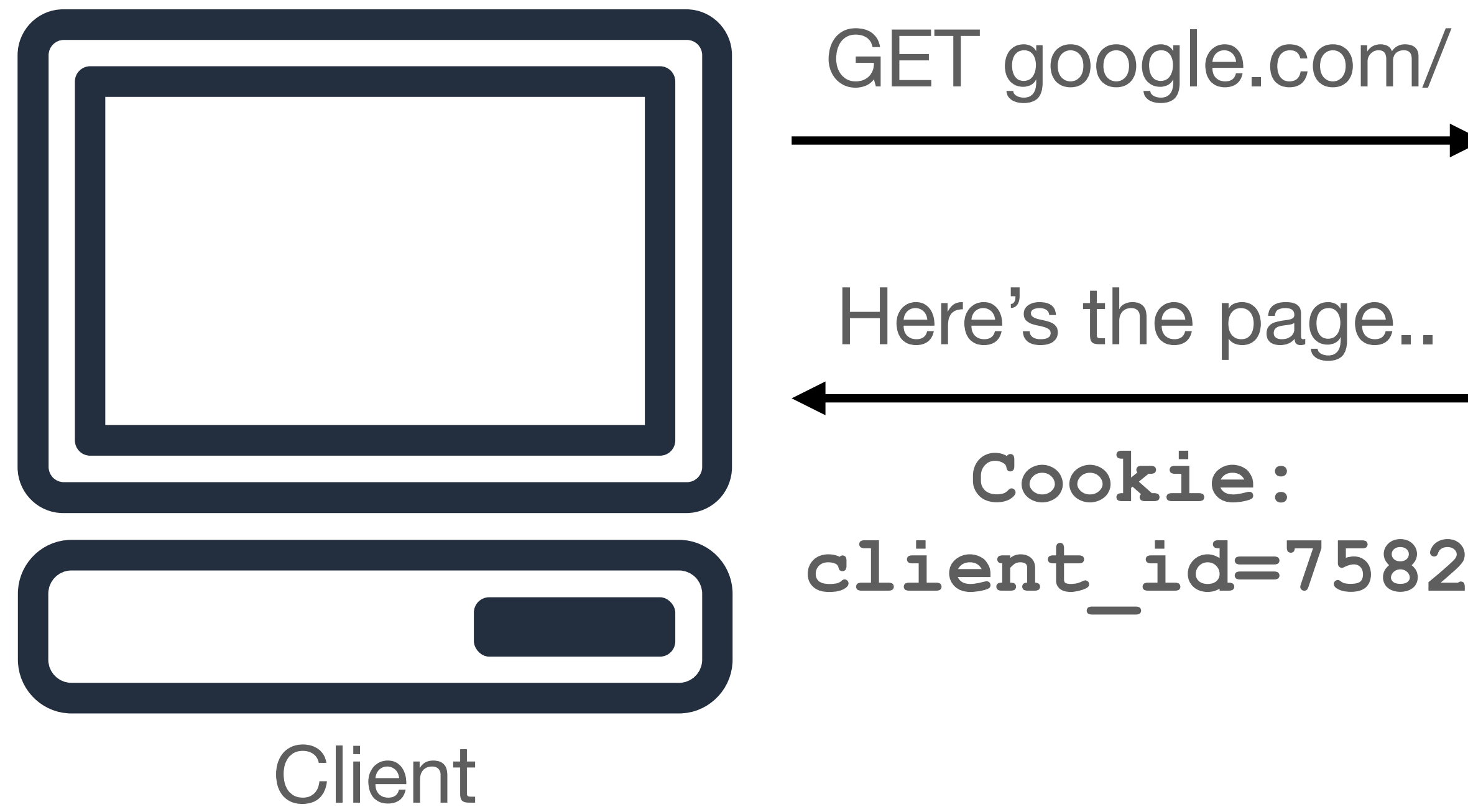
GET google.com/



google.com

Third-Party Tracking

- How does a company actually *track* you on the web using cookies? Seems like there's a lot of protections?



google.com

Third-Party Tracking

- How does a company actually *track* you on the web using cookies? Seems like there's a lot of protections?



Client

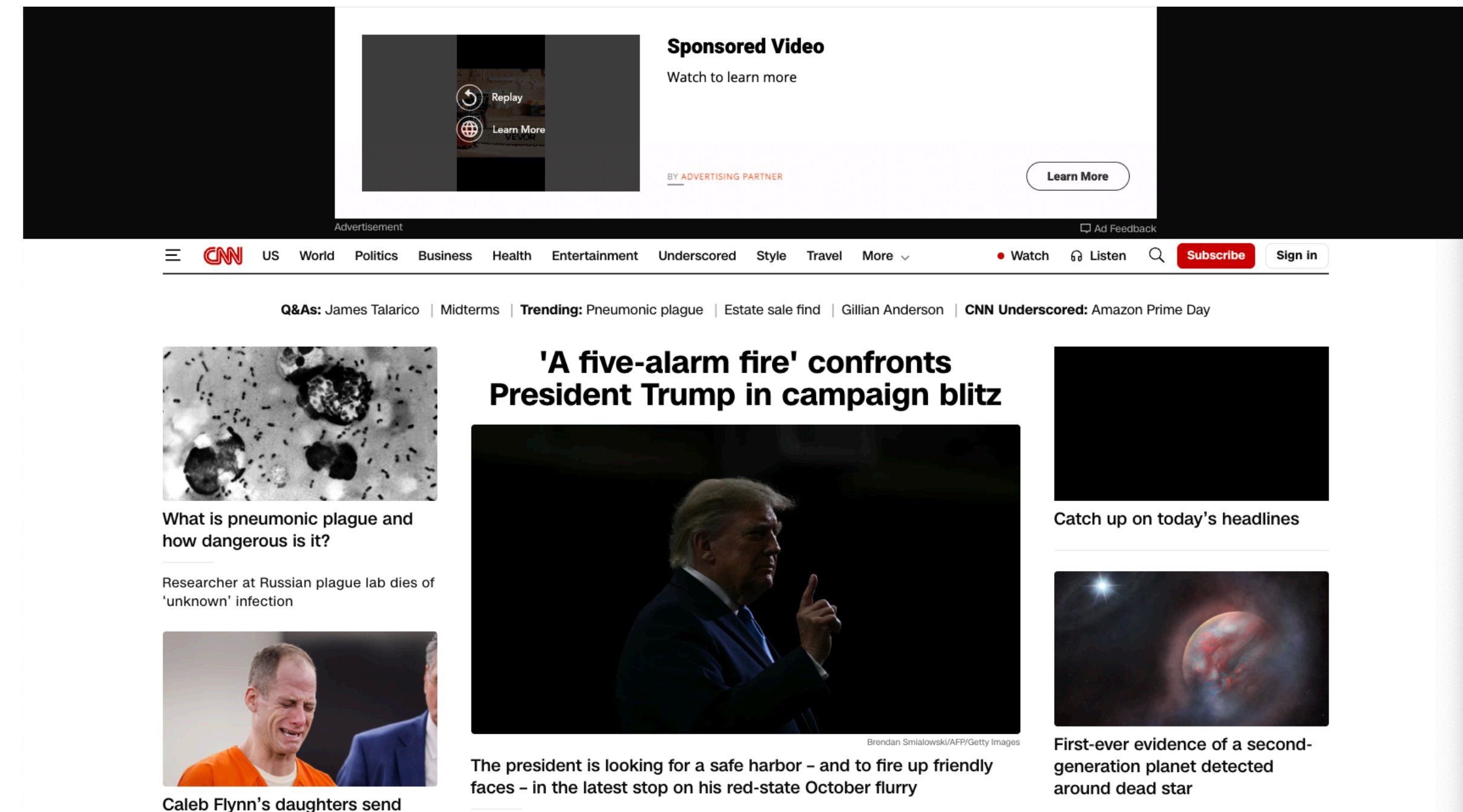
Third-Party Tracking

- How does a company actually *track* you on the web using cookies? Seems like there's a lot of protections?



Client

GET cnn.com/



cnn.com

Third-Party Tracking

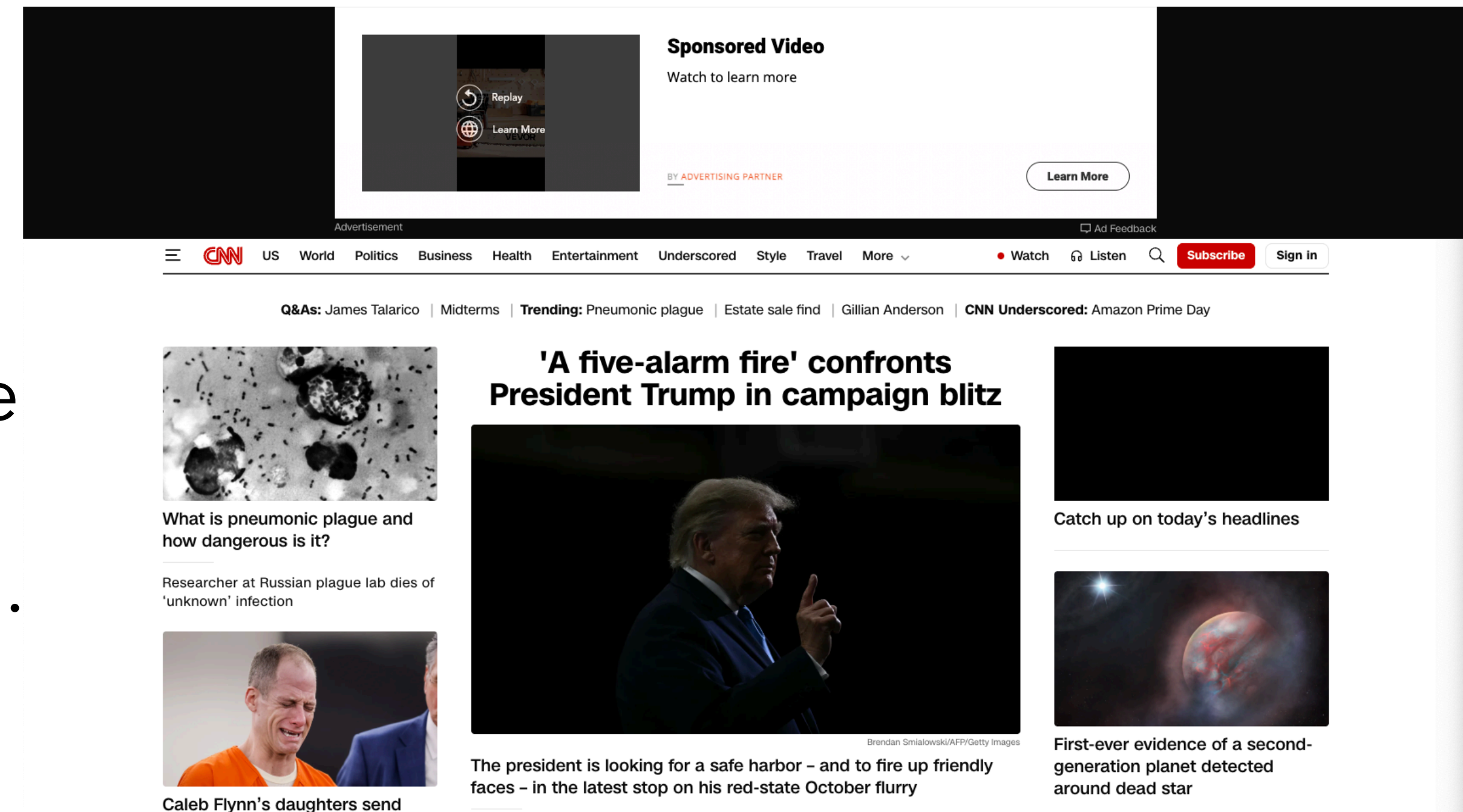
- How does a company actually *track* you on the web using cookies? Seems like there's a lot of protections?



Client

GET cnn.com/

By the time this page
has loaded, I have
already been tracked.
How?



cnn.com

Third-Party Tracking

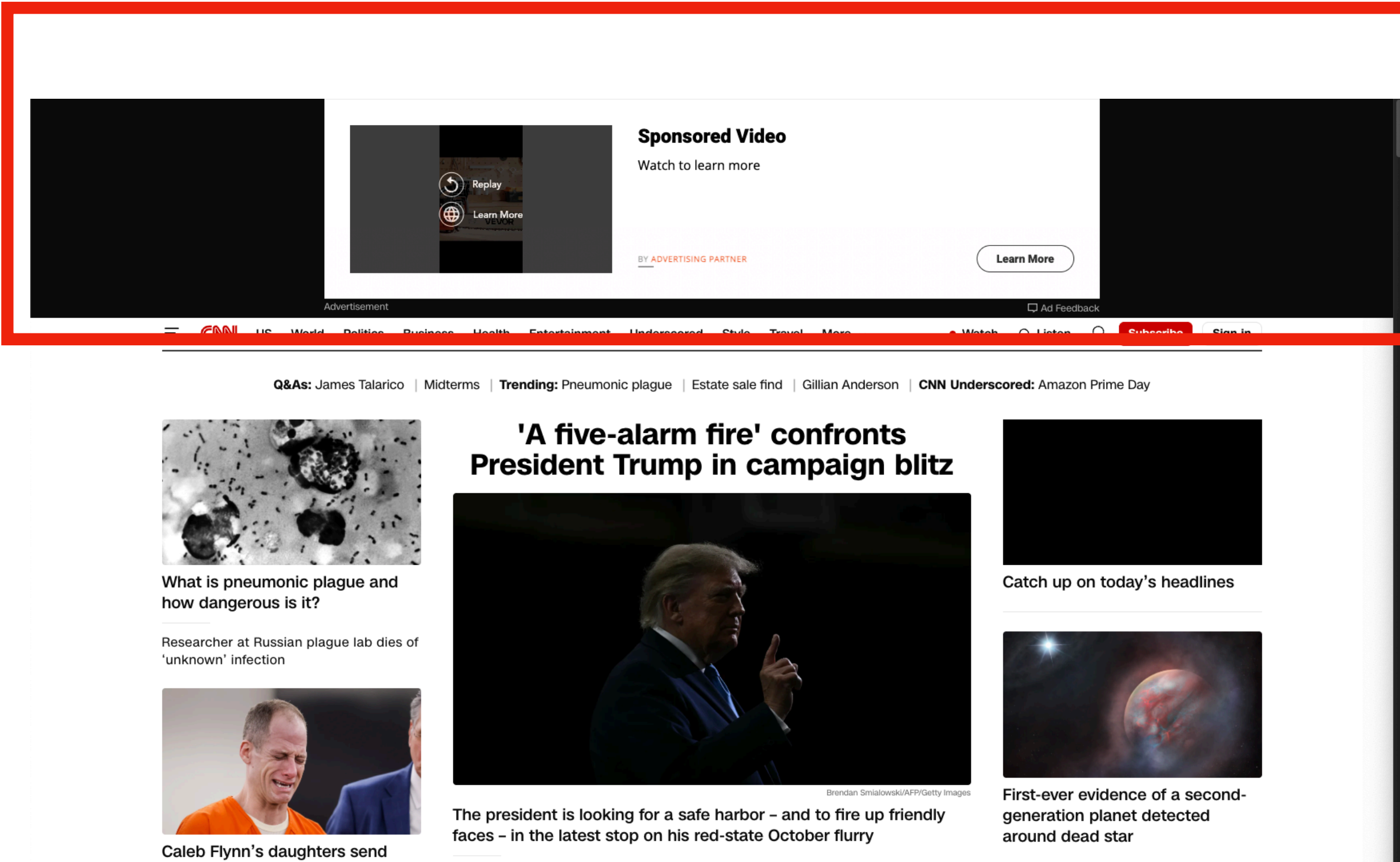
- How does a company actually track you on the web using cookies? Seems like

Where did this ad load from?



Client

GET cnn.com/



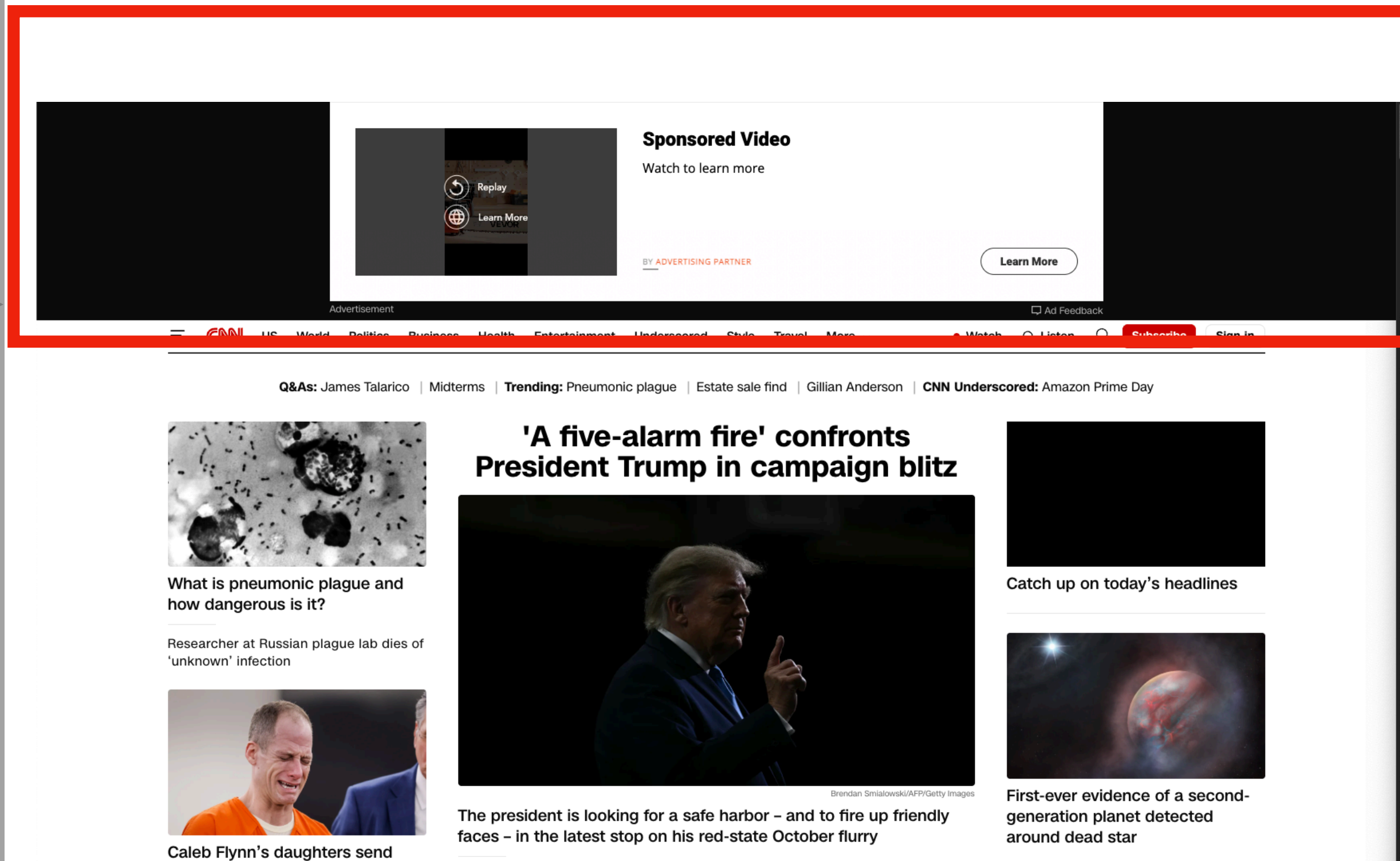
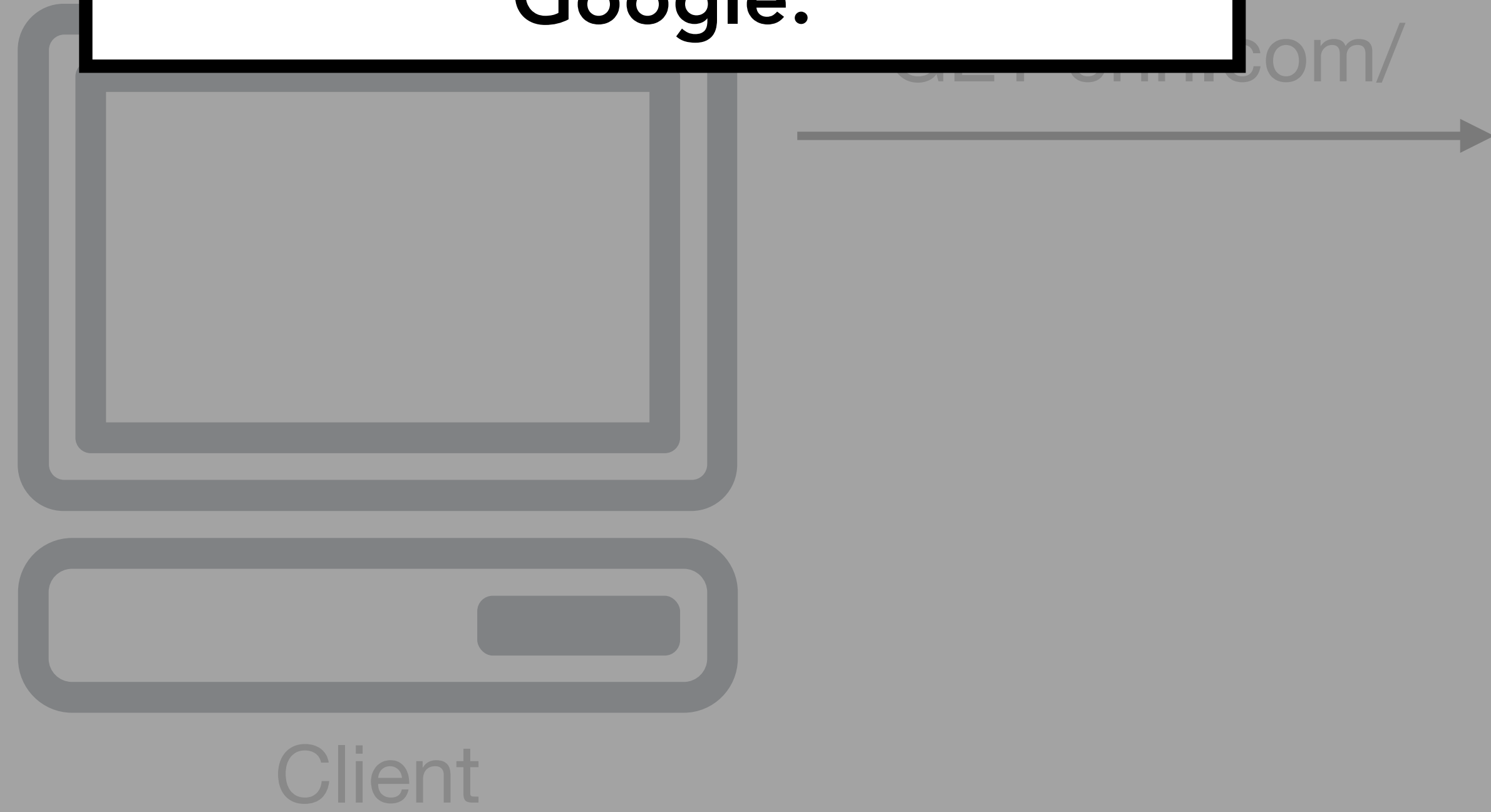
cnn.com

Third-Party Tracking

- How does a company actually track you on the web using cookies? Seems like

Where did this ad load from?

Google.



cnn.com

Third-Party Tracking

- How does a company actually track you on the web using cookies? Seems like

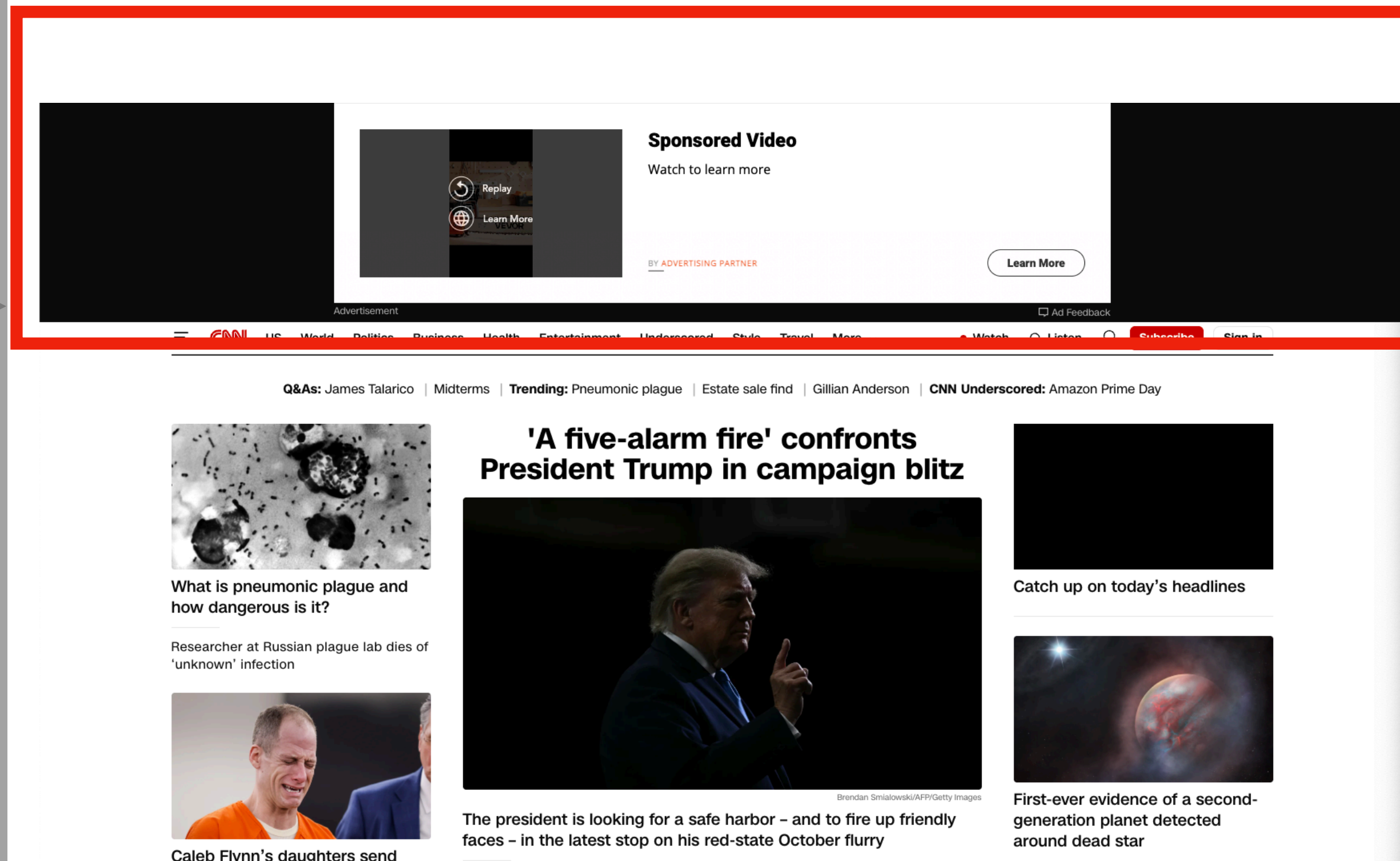
Where did this ad load from?

Google.

And what does the browser send when making requests to Google?

Client

on the web using cookies? Seems like



cnn.com

Third-Party Tracking

- How does a company actually track you on the web using cookies? Seems like

Where did this ad load from?

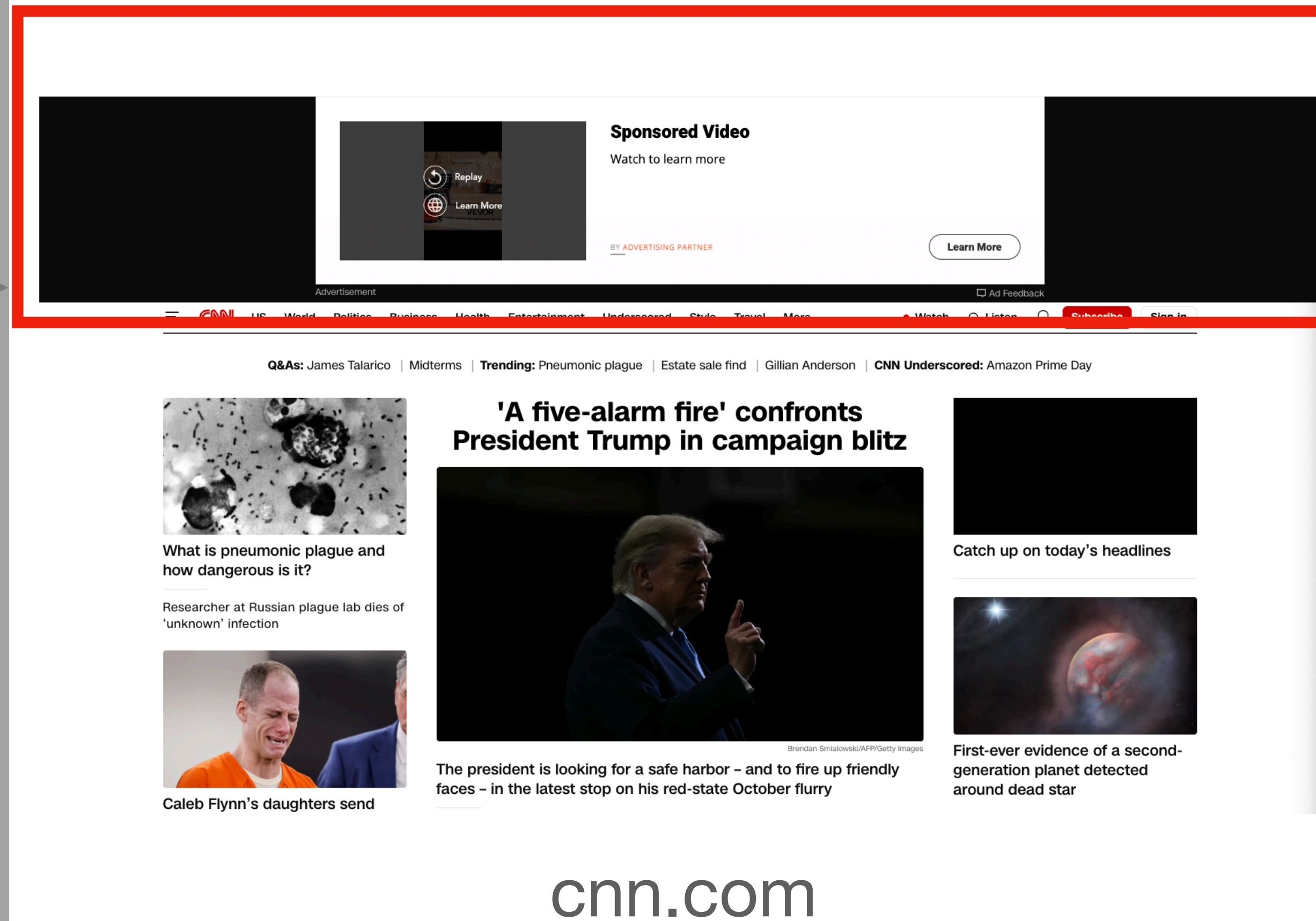
Google.

And what does the browser send when making requests to Google?

Cookies.

Client

on the web using cookies? Seems like



cnn.com

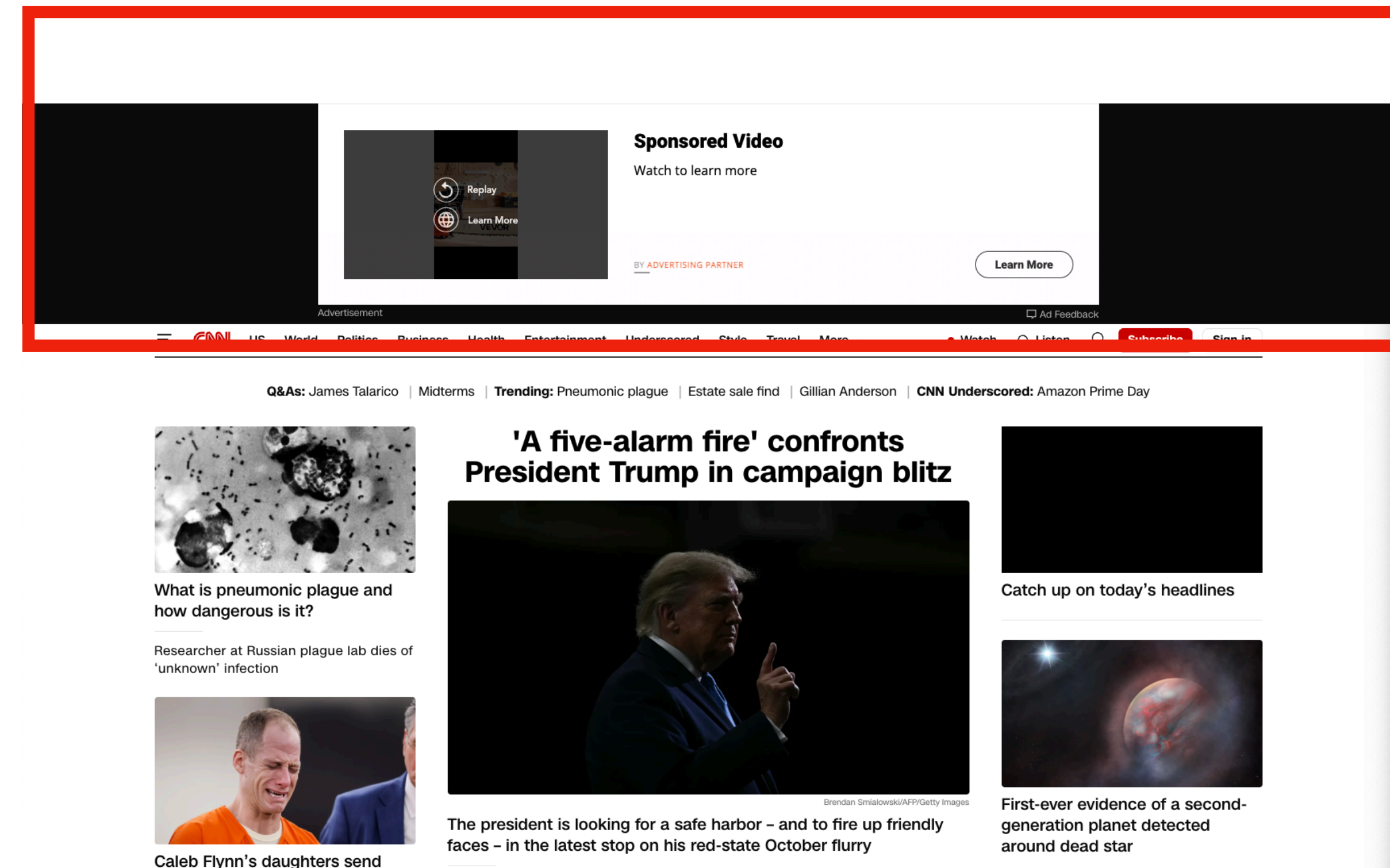
Third-Party Tracking

- How does a company actually *track* you on the web using cookies? Seems like there's a lot of protections?



GET google.com/ad

Cookie:
client_id=7582



cnn.com

Third-Party Tracking

- How does a company actually *track* you on the web using cookies? Seems like there's a lot of protections?

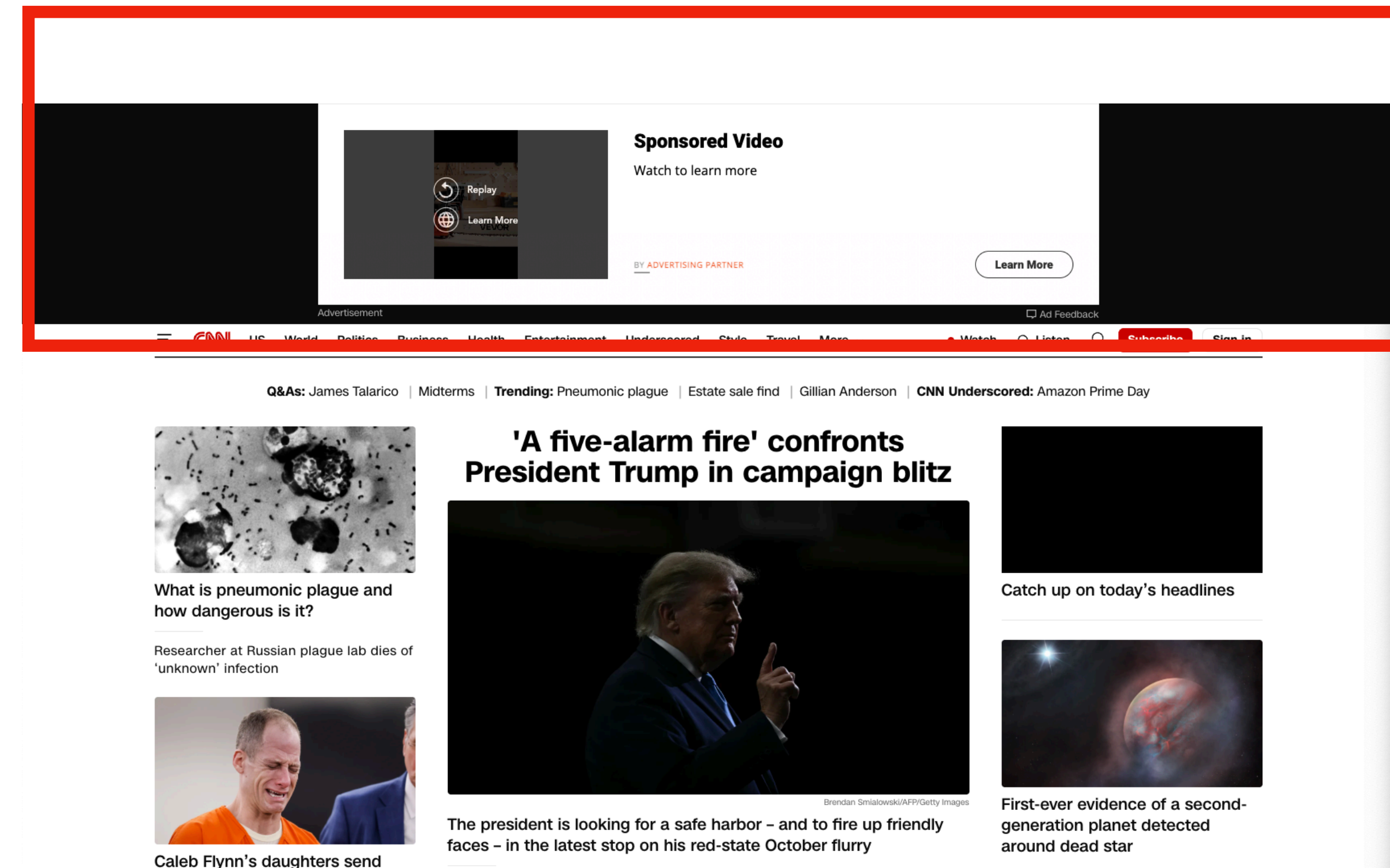


Client

GET google.com/ad

Cookie:
client_id=7582

Referer:
cnn.com



cnn.com

What does Google now know about me?

What does Google now know about me?

- They know I went to Google (and all my searches)
- They know I went to cnn.com
 - If I *click* on anything on cnn.com, they can know that too (assuming there's an ad on cnn.com)
- They know *when* I go anywhere on the Internet, assuming they have *any* kind of digital presence (e.g., an ad *requested* on the page)
 - Side note: Do ad blockers fix this problem?

What does Google now know about me?

- They know I went to Google (and all my searches)
- They know I went to cnn.com
 - If I *click* on anything on cnn.com, they can know that too (assuming there's an ad on cnn.com)
- They know *when* I go anywhere on the Internet, assuming they have *any* kind of digital presence (e.g., an ad *requested* on the page)
 - Side note: Do ad blockers fix this problem?
 - **They can, only if they block the request itself. Not all ad blockers do this uniformly.**

Surely, Google can't be in that many places, right?

Surely, Google can't be in that many places, right?

Wrong

- Major companies have large presences on the web, and as a result, can see the majority of websites that you visit
- Google appears on **82.2%** of the Top 1M, primarily because of analytics and advertising services
- Facebook appears on **34.1%**, to enable social sharing + tracking

Company	Prevalence on Top 1M
Google	82.2%
Facebook	34.1%
Amazon	32.6%
Cloudflare	30.7%
Akamai	20.3%
MaxCDN	19.0%
Edgecast	17.9%
Fastly	15.5%
SoftLayer	11.8%
Twitter	11.2%

Third Party Tracking is Everywhere

- Third-party cookies — cookies sent during a browsing instance that are *not to the page you're visiting*
- Third-party tracking has been, for most of the Internet, the de-facto way to track and follow you around as you browse
 - It happens transparently (without your knowledge) and is **built into the web ecosystem by default**

What can you do about it?

- Ultimately, use a browser that turns it off



Firefox



Brave



Safari

What can you do about it?

- Ultimately, use a browser that turns it off



Firefox



Brave



Safari

Who is conspicuously missing from this list?

TECHNOLOGY

After 4 years, Google backtracks on its discontinuation of third-party cookies

JULY 27, 2024 · 7:51 AM ET

HEARD ON WEEKEND EDITION SATURDAY



Google reneges on plan to remove third-party cookies in Chrome

By [Aimee Picchi](#)

Updated on: July 22, 2024 / 5:45 PM EDT / CBS News

 Add CBS News on Google



[About](#) [Issues](#) [Our Work](#) [Take Action](#) [Tools](#)

Google Breaks Promise to Block Third-Party Cookies

BY [LENA COHEN](#) | AUGUST 2, 2024

Chrome is so sad they can't block third-party cookies



"At the same time, we recognize this transition requires significant work by many participants and will have an impact on publishers, advertisers, and everyone involved in online advertising."

Google Chrome is Keeping the Third-Party Tracking Dream Alive

Google Chrome is Keeping the Third-Party Tracking Dream Alive



To be continued...

- The fight against third-party tracking, and the fight against the fight, and the fight against that fight, and.... you get it
- Work on PA1 part 2! Good luck!

